

5.23 Seguridad de la información para el uso de servicios en la nube

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# relación_proveedor- barcos_seguridad	# Gobernanza_y_ Ecosistema #Protec- ción

Control

Los procesos de adquisición, uso, gestión y salida de los servicios en la nube deben establecerse de acuerdo con los requisitos de seguridad de la información de la organización.

Objetivo

Especificar y administrar la seguridad de la información para el uso de servicios en la nube.

Guía

La organización debe establecer y comunicar una política específica sobre el uso de los servicios en la nube a todas las partes interesadas relevantes.

La organización debe definir y comunicar cómo pretende gestionar los riesgos de seguridad de la información asociados con el uso de servicios en la nube. Puede ser una extensión o parte del enfoque existente sobre cómo una organización gestiona los servicios proporcionados por terceros (ver [5.21](#) y [5.22](#)).

El uso de servicios en la nube puede implicar una responsabilidad compartida por la seguridad de la información y un esfuerzo de colaboración entre el proveedor del servicio en la nube y la organización que actúa como cliente del servicio en la nube. Es esencial que las responsabilidades tanto del proveedor de servicios en la nube como de la organización, que actúa como cliente del servicio en la nube, se definan e implementen de manera adecuada.

La organización debe definir:

- todos los requisitos de seguridad de la información pertinentes asociados con el uso de los servicios en la nube;
- criterios de selección del servicio en la nube y alcance del uso del servicio en la nube;
- funciones y responsabilidades relacionadas con el uso y la gestión de los servicios en la nube;
- qué controles de seguridad de la información gestiona el proveedor de servicios en la nube y cuáles gestiona la organización como cliente del servicio en la nube;
- cómo obtener y utilizar las capacidades de seguridad de la información proporcionadas por el proveedor de servicios en la nube;
- cómo obtener garantías sobre los controles de seguridad de la información implementados por los proveedores de servicios en la nube;
- cómo administrar los controles, las interfaces y los cambios en los servicios cuando una organización utiliza múltiples servicios en la nube, particularmente de diferentes proveedores de servicios en la nube;
- procedimientos para el manejo de incidentes de seguridad de la información que se produzcan en relación con el uso de los servicios en la nube;
- su enfoque para monitorear, revisar y evaluar el uso continuo de los servicios en la nube para administrar los riesgos de seguridad de la información;
- cómo cambiar o detener el uso de los servicios en la nube, incluidas las estrategias de salida para los servicios en la nube.

Los acuerdos de servicios en la nube a menudo están predefinidos y no están abiertos a negociación. Para todos los servicios en la nube, la organización debe revisar los acuerdos de servicios en la nube con los proveedores de servicios en la nube. Un acuerdo de servicio en la nube debe abordar los requisitos de confidencialidad, integridad, disponibilidad y manejo de la información de la organización, con objetivos de nivel de servicio en la nube y objetivos cualitativos de servicio en la nube apropiados. La organización también debería realizar evaluaciones de riesgos relevantes para identificar

los riesgos asociados con el uso del servicio en la nube. Cualquier riesgo residual relacionado con el uso del servicio en la nube debe ser claramente identificado y aceptado por la gerencia adecuada de la organización.

Un acuerdo entre el proveedor de servicios en la nube y la organización, que actúa como cliente del servicio en la nube, debe incluir las siguientes disposiciones para la protección de los datos de la organización y la disponibilidad de los servicios:

- a) proporcionar soluciones basadas en estándares aceptados por la industria para la arquitectura y la infraestructura;
- b) administrar los controles de acceso del servicio en la nube para cumplir con los requisitos de la organización;
- c) implementar soluciones de protección y monitoreo de malware;
- d) procesar y almacenar la información confidencial de la organización en ubicaciones aprobadas (p. ej., un país o una región en particular) o dentro o sujeto a una jurisdicción en particular;
- e) brindar soporte dedicado en caso de un incidente de seguridad de la información en el entorno del servicio en la nube;
- f) garantizar que se cumplan los requisitos de seguridad de la información de la organización en caso de que se subcontraten servicios en la nube a un proveedor externo (o se prohíba la subcontratación de servicios en la nube);
- g) apoyar a la organización en la recopilación de evidencia digital, teniendo en cuenta las leyes y regulaciones para evidencia digital en diferentes jurisdicciones;
- h) proporcionar soporte y disponibilidad de servicios apropiados durante un período de tiempo apropiado cuando la organización desea salir del servicio en la nube;
- i) proporcionar la copia de seguridad necesaria de los datos y la información de configuración y gestionar de forma segura las copias de seguridad, según corresponda, en función de las capacidades del proveedor de servicios en la nube utilizado por la organización, actuando como cliente del servicio en la nube;
- j) proporcionar y devolver información como archivos de configuración, código fuente y datos que son propiedad de la organización, actuando como cliente del servicio en la nube, cuando se solicite durante la prestación del servicio o al finalizar el servicio.

La organización, actuando como cliente del servicio en la nube, debe considerar si el acuerdo debe exigir a los proveedores de servicios en la nube que proporcionen una notificación previa antes de que se realicen cambios sustanciales que afecten al cliente en la forma en que se entrega el servicio a la organización, incluidos:

- a) cambios en la infraestructura técnica (p. ej., reubicación, reconfiguración o cambios en el hardware o el software) que afecten o modifiquen la oferta de servicios en la nube;
- b) procesar o almacenar información en una nueva jurisdicción geográfica o legal;
- c) uso de proveedores de servicios en la nube similares u otros subcontratistas (incluido el cambio de partes existentes o el uso de nuevas partes).

La organización que utiliza servicios en la nube debe mantener un estrecho contacto con sus proveedores de servicios en la nube. Estos contactos permiten el intercambio mutuo de información sobre la seguridad de la información para el uso de los servicios en la nube, incluido un mecanismo para que tanto el proveedor del servicio en la nube como la organización, que actúa como cliente del servicio en la nube, monitoreen cada característica del servicio e informen los incumplimientos de los compromisos contenidos en el acuerdo.

Otra información

Este control considera la seguridad en la nube desde la perspectiva del cliente del servicio en la nube.

Puede encontrar información adicional relacionada con los servicios en la nube en ISO/IEC 17788, ISO/IEC 17789 e ISO/IEC 22123-1. Los detalles relacionados con la portabilidad de la nube en apoyo de las estrategias de salida se pueden encontrar en ISO/IEC 19941. Los detalles relacionados con la seguridad de la información y los servicios de nube pública se describen en ISO/IEC 27017. Se describen los detalles relacionados con la protección de PII en nubes públicas que actúan como procesador de PII.

en ISO/IEC 27018. Las relaciones con los proveedores de servicios en la nube están cubiertas por ISO/IEC 27036-4 y los acuerdos de servicios en la nube y sus contenidos se tratan en la serie ISO/IEC 19086, con la seguridad y privacidad cubiertas específicamente por ISO/IEC 19086- 4.

5.24 Planificación y preparación de la gestión de incidentes de seguridad de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Correctivo	# Confidencialidad # Integridad # Disponibilidad	# Responder #Recuperar	# Gobernanza # Information_security_event_management	# Defensa

Control

La organización debe planificar y prepararse para la gestión de incidentes de seguridad de la información definiendo, estableciendo y comunicando procesos, funciones y responsabilidades de gestión de incidentes de seguridad de la información.

Objetivo

Garantizar una respuesta rápida, eficaz, coherente y ordenada a los incidentes de seguridad de la información, incluida la comunicación sobre eventos de seguridad de la información.

Guía

Funciones y responsabilidades

La organización debe establecer procesos apropiados de gestión de incidentes de seguridad de la información. Las funciones y responsabilidades para llevar a cabo los procedimientos de gestión de incidentes deben determinarse y comunicarse de manera efectiva a las partes interesadas internas y externas pertinentes.

Se debe considerar lo siguiente:

- establecer un método común para reportar eventos de seguridad de la información, incluido el punto de contacto (ver [6.8](#));
- establecer un proceso de gestión de incidentes para proporcionar a la organización la capacidad de gestionar incidentes de seguridad de la información, incluida la administración, documentación, detección, clasificación, priorización, análisis, comunicación y coordinación de las partes interesadas;
- establecer un proceso de respuesta a incidentes para proporcionar a la organización la capacidad de evaluar, responder y aprender de los incidentes de seguridad de la información;
- solo permitir que personal competente maneje los problemas relacionados con los incidentes de seguridad de la información dentro de la organización. Dicho personal debe contar con documentación de procedimientos y capacitación periódica;
- establecer un proceso para identificar la capacitación, la certificación y el desarrollo profesional continuo necesarios para el personal de respuesta a incidentes.

Procedimientos de gestión de incidentes

Los objetivos para la gestión de incidentes de seguridad de la información se deben acordar con la gerencia y se debe garantizar que los responsables de la gestión de incidentes de seguridad de la información entiendan las prioridades de la organización para manejar los incidentes de seguridad de la información, incluido el marco de tiempo de resolución basado en las posibles consecuencias y gravedad. Se deben implementar procedimientos de gestión de incidentes para cumplir con estos objetivos y prioridades.

La gerencia debe asegurarse de que se cree un plan de gestión de incidentes de seguridad de la información considerando diferentes escenarios y se desarrollen e implementen procedimientos para las siguientes actividades:

- a) evaluación de eventos de seguridad de la información según criterios de lo que constituye un incidente de seguridad de la información;
- b) monitoreo (ver [8.15](#) y [8.16](#)), detectar (ver [8.16](#)), clasificar (ver [5.25](#)), analizar e informar (ver [6.8](#)) de eventos e incidentes de seguridad de la información (por medios humanos o automáticos);
- c) gestionar los incidentes de seguridad de la información hasta su conclusión, incluida la respuesta y el escalamiento (ver [5.26](#)), según el tipo y la categoría del incidente, posible activación de gestión de crisis y activación de planes de continuidad, recuperación controlada de un incidente y comunicación a partes interesadas internas y externas;
- d) coordinación con partes interesadas internas y externas tales como autoridades, grupos de interés y foros externos, proveedores y clientes (ver [5.5](#) y [5.6](#));
- e) registrar las actividades de gestión de incidentes;
- f) manejo de evidencia (ver [5.28](#));
- g) análisis de causa raíz o procedimientos post-mortem;
- h) identificación de las lecciones aprendidas y de las mejoras a los procedimientos de gestión de incidentes o controles de seguridad de la información en general que se requieran.

Procedimientos de notificación

Los procedimientos de notificación deben incluir:

- a) acciones a tomar en caso de un evento de seguridad de la información (p. ej., tomar nota de todos los detalles pertinentes de inmediato, como el mal funcionamiento y los mensajes en pantalla, informar de inmediato al punto de contacto y solo tomar acciones coordinadas);
- b) uso de formularios de incidentes para ayudar al personal a realizar todas las acciones necesarias al informar incidentes de seguridad de la información;
- c) procesos de retroalimentación adecuados para asegurar que aquellas personas que reporten eventos de seguridad de la información sean notificadas, en la medida de lo posible, de los resultados después de que el problema haya sido abordado y cerrado;
- d) elaboración de informes de incidencias.

Cualquier requisito externo sobre el informe de incidentes a las partes interesadas relevantes dentro del marco de tiempo definido (por ejemplo, requisitos de notificación de incumplimiento a los reguladores) debe tenerse en cuenta al implementar los procedimientos de gestión de incidentes.

Otra información

Los incidentes de seguridad de la información pueden trascender las fronteras organizacionales y nacionales. Para responder a tales incidentes, es beneficioso coordinar la respuesta y compartir información sobre estos incidentes con organizaciones externas, según corresponda.

En la serie ISO/IEC 27035 se proporciona una guía detallada sobre la gestión de incidentes de seguridad de la información.

5.25 Evaluación y decisión sobre eventos de seguridad de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Detective	# Confidencialidad # Integridad # Disponibilidad	# Detectar #Responder	# Information_security_event_management	# Defensa

Control

La organización debería evaluar los eventos de seguridad de la información y decidir si se clasificarán como incidentes de seguridad de la información.

Objetivo

Para asegurar una categorización y priorización efectiva de los eventos de seguridad de la información.

Guía

Se debe acordar un esquema de categorización y priorización de incidentes de seguridad de la información para la identificación de las consecuencias y prioridad de un incidente. El esquema debe incluir los criterios para categorizar eventos como incidentes de seguridad de la información. El punto de contacto debe evaluar cada evento de seguridad de la información utilizando el esquema acordado.

El personal responsable de coordinar y responder a los incidentes de seguridad de la información debe realizar la evaluación y tomar una decisión sobre los eventos de seguridad de la información.

Los resultados de la evaluación y la decisión deben registrarse en detalle para fines de futura referencia y verificación.

Otra información

La serie ISO/IEC 27035 proporciona más orientación sobre la gestión de incidentes.

5.26 Respuesta a incidentes de seguridad de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Correctivo	# Confidencialidad # Integridad # Disponibilidad	# Responder #Recuperar	# Information_security_event_management	# Defensa

Control

Se debe responder a los incidentes de seguridad de la información de acuerdo con los procedimientos documentados.

Objetivo

Garantizar una respuesta eficiente y eficaz a los incidentes de seguridad de la información.

Guía

La organización debe establecer y comunicar procedimientos sobre la respuesta a incidentes de seguridad de la información a todas las partes interesadas pertinentes.

Los incidentes de seguridad de la información deben ser respondidos por un equipo designado con la competencia requerida (ver [5.24](#)).

La respuesta debe incluir lo siguiente:

- contener, si las consecuencias del incidente pueden extenderse, los sistemas afectados por el incidente;
- recopilar evidencia (ver [5.28](#)) tan pronto como sea posible después de la ocurrencia;
- escalamiento, según sea necesario, incluidas las actividades de gestión de crisis y posiblemente la invocación de planes de continuidad del negocio (ver [5.29](#) y [5.30](#));
- garantizar que todas las actividades de respuesta involucradas se registren correctamente para su posterior análisis;
- comunicar la existencia del incidente de seguridad de la información o cualquier detalle relevante del mismo a todas las partes interesadas internas y externas pertinentes siguiendo el principio de necesidad de saber;

- f) coordinarse con partes internas y externas como autoridades, grupos y foros de interés externos, proveedores y clientes para mejorar la eficacia de la respuesta y ayudar a minimizar las consecuencias para otras organizaciones;
- g) una vez solucionado satisfactoriamente el incidente, cerrarlo formalmente y registrarlo;
- h) realizar análisis forenses de seguridad de la información, según se requiera (ver [5.28](#));
- i) realizar un análisis posterior al incidente para identificar la causa raíz. Asegúrese de que esté documentado y comunicado de acuerdo con los procedimientos definidos (ver [5.27](#));
- j) identificar y gestionar las vulnerabilidades y debilidades de la seguridad de la información, incluidas las relacionadas con los controles que han causado, contribuido o fallado en prevenir el incidente.

Otra información

La serie ISO/IEC 27035 proporciona más orientación sobre la gestión de incidentes.

5.27 Aprendiendo de los incidentes de seguridad de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar # Proteger	# Information_security_event_management	# Defensa

Control

El conocimiento obtenido de los incidentes de seguridad de la información debe utilizarse para fortalecer y mejorar los controles de seguridad de la información.

Objetivo

Para reducir la probabilidad o las consecuencias de futuros incidentes.

Guía

La organización debe establecer procedimientos para cuantificar y monitorear los tipos, volúmenes y costos de los incidentes de seguridad de la información.

La información obtenida de la evaluación de incidentes de seguridad de la información debe utilizarse para:

- a) mejorar el plan de gestión de incidentes, incluidos los escenarios y procedimientos de incidentes (ver [5.24](#));
- b) identificar incidentes recurrentes o graves y sus causas para actualizar la evaluación de riesgos de seguridad de la información de la organización y determinar e implementar los controles adicionales necesarios para reducir la probabilidad o las consecuencias de futuros incidentes similares. Los mecanismos para habilitar eso incluyen recopilar, cuantificar y monitorear información sobre tipos de incidentes, volúmenes y costos;
- c) mejorar la concienciación y la formación de los usuarios (véase [6.3](#)) proporcionando ejemplos de lo que puede suceder, cómo responder a tales incidentes y cómo evitarlos en el futuro.

Otra información

La serie ISO/IEC 27035 proporciona más orientación.

5.28 Recopilación de pruebas

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Correctivo	# Confidencialidad # Integridad # Disponibilidad	# Detectar #Responder	# Information_security_event_management	# Defensa

Control

La organización debe establecer e implementar procedimientos para la identificación, recopilación, adquisición y preservación de evidencia relacionada con eventos de seguridad de la información.

Objetivo

Asegurar una gestión consistente y eficaz de la evidencia relacionada con incidentes de seguridad de la información para efectos de acciones disciplinarias y legales.

Guía

Se deben desarrollar y seguir procedimientos internos al tratar con evidencia relacionada con eventos de seguridad de la información con el propósito de acciones disciplinarias y legales. Se deben considerar los requisitos de las diferentes jurisdicciones para maximizar las posibilidades de admisión en las jurisdicciones relevantes.

En general, estos procedimientos para la gestión de pruebas deben proporcionar instrucciones para la identificación, recopilación, adquisición y conservación de pruebas de acuerdo con los diferentes tipos de medios de almacenamiento, dispositivos y estado de los dispositivos (es decir, encendidos o apagados). Por lo general, las pruebas deben recopilarse de una manera que sea admisible en los tribunales de justicia nacionales correspondientes u otro foro disciplinario. Debería ser posible demostrar que:

- a) los registros están completos y no han sido manipulados de ninguna manera;
- b) las copias de las pruebas electrónicas probablemente sean idénticas a los originales;
- c) cualquier sistema de información a partir del cual se hayan recopilado pruebas funcionaba correctamente en el momento en que se registraron las pruebas.

Cuando esté disponible, se debe buscar la certificación u otros medios relevantes de calificación del personal y las herramientas, para fortalecer el valor de la evidencia preservada.

La evidencia digital puede trascender los límites organizacionales o jurisdiccionales. En tales casos, se debe garantizar que la organización tenga derecho a recopilar la información requerida como evidencia digital.

Otra información

Cuando se detecta por primera vez un evento de seguridad de la información, no siempre es obvio si el evento resultará o no en una acción judicial. Por lo tanto, existe el peligro de que las pruebas necesarias se destruyan intencional o accidentalmente antes de darse cuenta de la gravedad del incidente. Es aconsejable involucrar asesoramiento legal o aplicación de la ley desde el principio en cualquier acción legal contemplada y recibir asesoramiento sobre las pruebas requeridas.

ISO/IEC 27037 proporciona definiciones y pautas para la identificación, recolección, adquisición y preservación de evidencia digital.

La serie ISO/IEC 27050 se ocupa del descubrimiento electrónico, que implica el procesamiento de información almacenada electrónicamente como prueba.

5.29 Seguridad de la información durante la interrupción

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo #Cor- correctivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger #Responder	# Continuidad	# Protección # Resiliencia

Control

La organización debe planificar cómo mantener la seguridad de la información en un nivel adecuado durante la interrupción.

Objetivo

Para proteger la información y otros activos asociados durante la interrupción.

Guía

La organización debe determinar sus requisitos para adaptar los controles de seguridad de la información durante la interrupción. Los requisitos de seguridad de la información deben incluirse en los procesos de gestión de la continuidad del negocio.

Los planes deben desarrollarse, implementarse, probarse, revisarse y evaluarse para mantener o restaurar la seguridad de la información de los procesos comerciales críticos luego de una interrupción o falla. La seguridad de la información debe restaurarse al nivel requerido y en los plazos requeridos.

La organización debe implementar y mantener:

- a) controles de seguridad de la información, sistemas y herramientas de apoyo dentro de los planes de continuidad del negocio y continuidad de las TIC;
- b) procesos para mantener los controles de seguridad de la información existentes durante la interrupción;
- c) controles de compensación para los controles de seguridad de la información que no se pueden mantener durante la interrupción.

Otra información

En el contexto de la continuidad del negocio y la planificación de la continuidad de las TIC, puede ser necesario adaptar los requisitos de seguridad de la información según el tipo de interrupción, en comparación con las condiciones operativas normales. Como parte del análisis de impacto comercial y la evaluación de riesgos realizados dentro de la gestión de continuidad comercial, se deben considerar y priorizar las consecuencias de la pérdida de confidencialidad e integridad de la información, además de la necesidad de mantener la disponibilidad.

La información sobre los sistemas de gestión de la continuidad del negocio se puede encontrar en ISO 22301 e ISO 22313. Se puede encontrar más orientación sobre el análisis de impacto en el negocio (BIA) en ISO/TS 22317.

5.30 Preparación de las TIC para la continuidad del negocio

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Correctivo	# Disponibilidad	# Responder	# Continuidad	# Resiliencia

Control

La preparación de las TIC debe planificarse, implementarse, mantenerse y probarse en función de los objetivos de continuidad del negocio y los requisitos de continuidad de las TIC.

Objetivo

Para garantizar la disponibilidad de la información de la organización y otros activos asociados durante la interrupción.

Guía

La preparación de las TIC para la continuidad del negocio es un componente importante en la gestión de la continuidad del negocio y la gestión de la seguridad de la información para garantizar que los objetivos de la organización puedan seguir cumpliéndose durante la interrupción.

Los requisitos de continuidad de las TIC son el resultado del análisis de impacto empresarial (BIA). El proceso BIA debe utilizar tipos y criterios de impacto para evaluar los impactos a lo largo del tiempo que resultan de la interrupción de las actividades comerciales que entregan productos y servicios. La magnitud y la duración del impacto resultante deben usarse para identificar actividades prioritarias a las que se les debe asignar un objetivo de tiempo de recuperación (RTO). El BIA debe entonces determinar qué recursos se necesitan para apoyar las actividades priorizadas. También se debe especificar un RTO para estos recursos. Un subconjunto de estos recursos debería incluir servicios de TIC.

El BIA relacionado con los servicios de TIC se puede ampliar para definir los requisitos de rendimiento y capacidad de los sistemas de TIC y los objetivos de punto de recuperación (RPO) de la información necesaria para respaldar las actividades durante la interrupción.

Con base en los resultados del BIA y la evaluación de riesgos relacionados con los servicios de TIC, la organización debe identificar y seleccionar estrategias de continuidad de las TIC que consideren opciones para antes, durante y después de la interrupción. Las estrategias de continuidad del negocio pueden comprender una o más soluciones. Con base en las estrategias, los planes deben desarrollarse, implementarse y probarse para cumplir con el nivel de disponibilidad requerido de los servicios de TIC y en los plazos requeridos luego de la interrupción o falla de los procesos críticos.

La organización debe asegurarse de que:

- a) existe una estructura organizativa adecuada para prepararse, mitigar y responder a una interrupción con el apoyo de personal con la responsabilidad, autoridad y competencia necesarias;
- b) Los planes de continuidad de las TIC, incluidos los procedimientos de respuesta y recuperación que detallan cómo la organización planea gestionar una interrupción del servicio de TIC, son:
 - 1) evaluado regularmente a través de ejercicios y pruebas;
 - 2) aprobado por la gerencia;
- c) Los planes de continuidad TIC incluyen la siguiente información de continuidad TIC:
 - 1) especificaciones de rendimiento y capacidad para cumplir con los requisitos y objetivos de continuidad del negocio como se especifica en el BIA;
 - 2) RTO de cada servicio TIC priorizado y los procedimientos para restaurar esos componentes;
 - 3) RPO de los recursos TIC priorizados definidos como información y los procedimientos para restaurar la información.

Otra información

La gestión de la continuidad de las TIC constituye una parte clave de los requisitos de continuidad del negocio en relación con la disponibilidad para poder:

- a) responder y recuperarse de la interrupción de los servicios de TIC, independientemente de la causa;
- b) garantizar que la continuidad de las actividades prioritarias esté respaldada por los servicios de TIC requeridos;
- c) responder antes de que ocurra una interrupción de los servicios de TIC, y al detectar al menos un incidente que pueda resultar en una interrupción de los servicios de TIC.

Se puede encontrar más orientación sobre la preparación de las TIC para la continuidad del negocio en ISO/IEC 27031.

Puede encontrar más orientación sobre los sistemas de gestión de la continuidad del negocio en las normas ISO 22301 e ISO 22313.

Se puede encontrar más orientación sobre BIA en ISO/TS 22317.

5.31 Requisitos legales, estatutarios, reglamentarios y contractuales

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar	# Legal_and_compliance	# Gobernanza_y_Ecosistema # Protección

Control

Los requisitos legales, estatutarios, reglamentarios y contractuales relevantes para la seguridad de la información y el enfoque de la organización para cumplir con estos requisitos deben identificarse, documentarse y mantenerse actualizados.

Objetivo

Asegurar el cumplimiento de los requisitos legales, estatutarios, reglamentarios y contractuales relacionados con la seguridad de la información.

Guía

General

Los requisitos externos, incluidos los requisitos legales, estatutarios, reglamentarios o contractuales, deben tenerse en cuenta cuando:

- desarrollar políticas y procedimientos de seguridad de la información;
- diseñar, implementar o cambiar los controles de seguridad de la información;
- clasificar la información y otros activos asociados como parte del proceso para establecer requisitos de seguridad de la información para necesidades internas o para acuerdos con proveedores;
- realizar evaluaciones de riesgos de seguridad de la información y determinar las actividades de tratamiento de riesgos de seguridad de la información;
- determinar los procesos junto con las funciones y responsabilidades relacionadas con la seguridad de la información;
- determinar los requisitos contractuales de los proveedores relevantes para la organización y el alcance del suministro de productos y servicios.

Legislación y reglamentos

La organización debería:

- identificar toda la legislación y los reglamentos pertinentes a la seguridad de la información de la organización para conocer los requisitos para su tipo de negocio;
- tomar en consideración el cumplimiento en todos los países relevantes, si la organización:
 - realiza negocios en otros países;
 - usa productos y servicios de otros países donde las leyes y reglamentos pueden afectar a la organización;

— transfiere información a través de fronteras jurisdiccionales donde las leyes y reglamentos pueden afectar a la organización;

- c) revisar periódicamente la legislación y los reglamentos identificados para mantenerse al día con los cambios e identificar nueva legislación;
- d) definir y documentar los procesos específicos y las responsabilidades individuales para cumplir con estos requisitos.

Criptografía

La criptografía es un área que a menudo tiene requisitos legales específicos. Se debe tener en cuenta el cumplimiento de los acuerdos, leyes y reglamentos pertinentes relacionados con los siguientes elementos:

- a) restricciones a la importación o exportación de hardware y software informático para realizar funciones criptográficas;
- b) restricciones a la importación o exportación de hardware y software informático que esté diseñado para tener funciones criptográficas añadidas;
- c) restricciones en el uso de criptografía;
- d) métodos obligatorios o discrecionales de acceso por parte de las autoridades de los países a la información cifrada;
- e) vigencia de firmas digitales, sellos y certificados.

Se recomienda buscar asesoramiento legal al garantizar el cumplimiento de la legislación y las reglamentaciones pertinentes, especialmente cuando la información cifrada o las herramientas criptográficas se mueven a través de las fronteras jurisdiccionales.

Contratos

Los requisitos contractuales relacionados con la seguridad de la información deben incluir los establecidos en:

- a) contratos con clientes;
- b) contratos con proveedores (ver [5.20](#));
- c) contratos de seguro.

Otra información

Ninguna otra información.

5.32 Derechos de propiedad intelectual

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar	# Legal_and_compliance	# Gobernanza_y_Ecosistema

Control

La organización debe implementar procedimientos apropiados para proteger los derechos de propiedad intelectual.

Objetivo

Para garantizar el cumplimiento de los requisitos legales, estatutarios, reglamentarios y contractuales relacionados con los derechos de propiedad intelectual y el uso de productos patentados.

Guía

Se deben considerar las siguientes pautas para proteger cualquier material que pueda considerarse propiedad intelectual:

- a) definir y comunicar una política específica sobre la protección de los derechos de propiedad intelectual;
- b) publicar procedimientos para el cumplimiento de los derechos de propiedad intelectual que definan el uso conforme de software y productos de información;
- c) adquirir software solo a través de fuentes conocidas y acreditadas, para garantizar que no se infrinjan los derechos de autor;
- d) mantener registros de activos apropiados e identificar todos los activos con requisitos para proteger los derechos de propiedad intelectual;
- e) mantener prueba y evidencia de propiedad de licencias, manuales, etc.;
- f) asegurarse de que no se exceda el número máximo de usuarios o recursos [por ejemplo, unidades centrales de procesamiento (CPU)] permitido dentro de la licencia;
- g) llevar a cabo revisiones para garantizar que solo se instalen software autorizado y productos con licencia;
- h) proporcionar procedimientos para mantener las condiciones apropiadas de la licencia;
- i) proporcionar procedimientos para desechar o transferir software a otros;
- j) cumplir con los términos y condiciones del software y la información obtenida de redes públicas y fuentes externas;
- k) no duplicar, convertir a otro formato o extraer de grabaciones comerciales (video, audio) que no sea lo permitido por la ley de derechos de autor o las licencias aplicables;
- l) no copiar, total o parcialmente, estándares (p. ej., estándares internacionales ISO/IEC), libros, artículos, informes u otros documentos, salvo lo permitido por la ley de derechos de autor o las licencias aplicables.

Otra información

Los derechos de propiedad intelectual incluyen derechos de autor de software o documentos, derechos de diseño, marcas registradas, patentes y licencias de código fuente.

Los productos de software patentados generalmente se suministran bajo un acuerdo de licencia que especifica los términos y condiciones de la licencia, por ejemplo, limitando el uso de los productos a máquinas específicas o limitando la copia a la creación de copias de seguridad únicamente. Consulte la serie ISO/IEC 19770 para obtener detalles sobre la gestión de activos de TI.

Los datos se pueden obtener de fuentes externas. En general, se da el caso de que dichos datos se obtienen bajo los términos de un acuerdo de intercambio de datos o un instrumento legal similar. Dichos acuerdos de intercambio de datos deben dejar claro qué procesamiento está permitido para los datos adquiridos. También es recomendable que se indique claramente la procedencia de los datos. Ver ISO/IEC 23751:—1) para obtener detalles sobre los acuerdos de intercambio de datos.

Los requisitos legales, estatutarios, reglamentarios y contractuales pueden imponer restricciones a la copia de material patentado. En particular, pueden exigir que solo se pueda utilizar el material desarrollado por la organización o que el desarrollador haya autorizado o proporcionado a la organización. La infracción de los derechos de autor puede dar lugar a acciones legales, que pueden implicar multas y procesos penales.

Además de la necesidad de que la organización cumpla con sus obligaciones con respecto a los derechos de propiedad intelectual de terceros, también se deben gestionar los riesgos del personal y de terceros que no respeten los derechos de propiedad intelectual de la organización.

1) En preparación. Etapa en el momento de la publicación: ISO/IEC PRF 23751:2022.

5.33 Protección de registros

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Seguridad do- red eléctrica
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar # Proteger	# Legal_y_cumplimiento # Gestión de activos # Information_protec- ción	# Defensa

Control

Los registros deben protegerse contra pérdida, destrucción, falsificación, acceso no autorizado y publicación no autorizada.

Objetivo

Para garantizar el cumplimiento de los requisitos legales, estatutarios, reglamentarios y contractuales, así como las expectativas de la comunidad o la sociedad relacionadas con la protección y disponibilidad de los registros.

Guía

La organización debe tomar los siguientes pasos para proteger la autenticidad, confiabilidad, integridad y usabilidad de los registros, ya que su contexto comercial y los requisitos para su gestión cambian con el tiempo:

- a) emitir lineamientos sobre el almacenamiento, el manejo de la cadena de custodia y la eliminación de registros, lo que incluye la prevención de la manipulación de registros. Estas pautas deben estar alineadas con la política específica del tema de la organización sobre la gestión de registros y otros requisitos de registros;
- b) elaborar un calendario de conservación que defina los registros y el período de tiempo durante el cual deben conservarse.

El sistema de almacenamiento y manejo debe garantizar la identificación de los registros y de su período de retención teniendo en cuenta la legislación o los reglamentos nacionales o regionales, así como las expectativas de la comunidad o la sociedad, si corresponde. Este sistema debería permitir la destrucción adecuada de registros después de ese período si la organización no los necesita.

Al decidir sobre la protección de registros organizacionales específicos, se debe considerar su clasificación de seguridad de la información correspondiente, con base en el esquema de clasificación de la organización. Los registros deben clasificarse en tipos de registros (p. ej., registros contables, registros de transacciones comerciales, registros de personal, registros legales), cada uno con detalles sobre los períodos de retención y el tipo de medio de almacenamiento permitido, que puede ser físico o electrónico.

Los sistemas de almacenamiento de datos deben elegirse de manera que los registros requeridos puedan recuperarse en un marco de tiempo y formato aceptables, según los requisitos que se deban cumplir.

Cuando se elijan medios de almacenamiento electrónico, se deben establecer procedimientos para garantizar la capacidad de acceder a los registros (tanto los medios de almacenamiento como la legibilidad del formato) durante todo el período de retención para salvaguardar contra pérdidas debido a futuros cambios tecnológicos. Cualquier clave criptográfica relacionada y programas asociados con archivos cifrados o firmas digitales también deben conservarse para permitir el descifrado de los registros durante el tiempo que se conservan los registros (ver [8.24](#)).

Los procedimientos de almacenamiento y manipulación deben implementarse de acuerdo con las recomendaciones proporcionadas por los fabricantes de los medios de almacenamiento. Se debe considerar la posibilidad de deterioro de los medios utilizados para el almacenamiento de registros.

Otra información

Los registros documentan eventos o transacciones individuales o pueden formar agregados que han sido diseñados para documentar procesos de trabajo, actividades o funciones. Ambos son evidencia de actividad comercial y activos de información. Cualquier conjunto de información, independientemente de su estructura o forma, puede gestionarse como un

registro. Esto incluye información en forma de documento, una recopilación de datos u otros tipos de información digital o análoga que se crean, capturan y gestionan en el curso del negocio.

En la gestión de documentos, los metadatos son datos que describen el contexto, el contenido y la estructura de los documentos, así como su gestión a lo largo del tiempo. Los metadatos son un componente esencial de cualquier registro.

Puede ser necesario conservar algunos registros de forma segura para cumplir con los requisitos legales, estatutarios, reglamentarios o contractuales, así como para respaldar las actividades comerciales esenciales. La ley o regulación nacional puede establecer el período de tiempo y el contenido de los datos para la retención de la información. Puede encontrar más información sobre la gestión de registros en la norma ISO 15489.

5.34 Privacidad y protección de PII

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Seguridad do- red eléctrica
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar # Proteger	# Información_protección # Legal_y_cumplimiento	# Protección

Control

La organización debe identificar y cumplir los requisitos relacionados con la preservación de la privacidad y la protección de la PII de acuerdo con las leyes y reglamentos aplicables y los requisitos contractuales.

Objetivo

Para garantizar el cumplimiento de los requisitos legales, estatutarios, reglamentarios y contractuales relacionados con los aspectos de seguridad de la información de la protección de PII.

Guía

La organización debe establecer y comunicar una política de privacidad y protección de PII específica del tema a todas las partes interesadas pertinentes.

La organización debe desarrollar e implementar procedimientos para la preservación de la privacidad y la protección de la PII. Estos procedimientos deben comunicarse a todas las partes interesadas relevantes involucradas en el procesamiento de información de identificación personal.

El cumplimiento de estos procedimientos y de toda la legislación y los reglamentos pertinentes relacionados con la preservación de la privacidad y la protección de la PII requiere roles, responsabilidades y controles apropiados. A menudo, esto se logra mejor mediante el nombramiento de una persona responsable, como un oficial de privacidad, que debe brindar orientación al personal, los proveedores de servicios y otras partes interesadas sobre sus responsabilidades individuales y los procedimientos específicos que deben seguirse.

La responsabilidad por el manejo de la PII debe abordarse teniendo en cuenta la legislación y los reglamentos pertinentes.

Se deben implementar medidas técnicas y organizativas apropiadas para proteger la PII.

Otra información

Varios países han introducido legislación que impone controles sobre la recopilación, el procesamiento, la transmisión y la eliminación de PII. Dependiendo de la legislación nacional respectiva, dichos controles pueden imponer obligaciones a quienes recopilan, procesan y difunden PII y también pueden restringir la autoridad para transferir PII a otros países.

ISO/IEC 29100 proporciona un marco de alto nivel para la protección de PII dentro de los sistemas de TIC. Se puede encontrar más información sobre los sistemas de gestión de información de privacidad en ISO/IEC 27701. Se puede encontrar información específica sobre la gestión de información de privacidad para nubes públicas que actúan como procesadores de PII en ISO/IEC 27018.

ISO/IEC 29134 proporciona pautas para la evaluación del impacto en la privacidad (PIA) y brinda un ejemplo de la estructura y el contenido de un informe PIA. En comparación con ISO/IEC 27005, se centra en el procesamiento de PII y es relevante para aquellas organizaciones que procesan PII. Esto puede ayudar a identificar los riesgos de privacidad y las posibles mitigaciones para reducir estos riesgos a niveles aceptables.

5.35 Revisión independiente de la seguridad de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo #Cor- correctivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar # Proteger	# Information secu- rity_assurance	# Gobernanza_y_ Ecosistema

Control

El enfoque de la organización para gestionar la seguridad de la información y su implementación, incluidas las personas, los procesos y las tecnologías, debe revisarse de forma independiente a intervalos planificados o cuando se produzcan cambios significativos.

Objetivo

Asegurar la idoneidad, adecuación y eficacia continuas del enfoque de la organización para gestionar la seguridad de la información.

Guía

La organización debe tener procesos para realizar revisiones independientes.

La gerencia debe planificar e iniciar revisiones periódicas independientes. Las revisiones deben incluir la evaluación de las oportunidades de mejora y la necesidad de cambios en el enfoque de la seguridad de la información, incluida la política de seguridad de la información, las políticas de temas específicos y otros controles.

Dichas revisiones deben ser realizadas por personas independientes del área bajo revisión (por ejemplo, la función de auditoría interna, un gerente independiente o una organización externa especializada en tales revisiones). Las personas que lleven a cabo estas revisiones deben tener la competencia adecuada. La persona que realiza las revisiones no debe estar en la línea de autoridad para garantizar que tenga la independencia para realizar una evaluación.

Los resultados de las revisiones independientes deben informarse a la dirección que inició las revisiones y, si procede, a la alta dirección. Estos registros deben mantenerse.

Si las revisiones independientes identifican que el enfoque y la implementación de la organización para gestionar la seguridad de la información son inadecuados [por ejemplo, los objetivos y requisitos documentados no se cumplen o no cumplen con la dirección para la seguridad de la información establecida en la política de seguridad de la información y las políticas específicas del tema (ver [5.1](#))], la gerencia debe iniciar acciones correctivas.

Además de las revisiones independientes periódicas, la organización debería considerar la realización de revisiones independientes cuando:

- a) leyes y reglamentos que afectan el cambio de la organización;
- b) ocurren incidentes significativos;
- c) la organización inicia un nuevo negocio o cambia un negocio actual;
- d) la organización comienza a usar un nuevo producto o servicio, o cambia el uso de un producto o servicio actual;
- e) la organización cambia significativamente los controles y procedimientos de seguridad de la información.

Otra información

ISO/IEC 27007 e ISO/IEC TS 27008 brindan orientación para llevar a cabo revisiones independientes.

5.36 Cumplimiento de políticas, normas y estándares de seguridad de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Capacidad operativa idades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Identificar # Proteger	# Legal_and_compliance # Information_security_assurance	# Gobernanza_y_Ecosistema

Control

El cumplimiento de la política de seguridad de la información de la organización, las políticas específicas del tema, las reglas y los estándares debe revisarse periódicamente.

Objetivo

Para garantizar que la seguridad de la información se implemente y opere de acuerdo con la política de seguridad de la información de la organización, las políticas, las reglas y los estándares específicos del tema.

Guía

Los gerentes, propietarios de servicios, productos o información deben identificar cómo revisar que se cumplan los requisitos de seguridad de la información definidos en la política de seguridad de la información, las políticas específicas del tema, las reglas, los estándares y otras reglamentaciones aplicables. Se deben considerar herramientas automáticas de medición y generación de informes para una revisión periódica eficiente.

Si se encuentra algún incumplimiento como resultado de la revisión, los gerentes deben:

- a) identificar las causas del incumplimiento;
- b) evaluar la necesidad de acciones correctivas para lograr el cumplimiento;
- c) implementar acciones correctivas apropiadas;
- d) revisar las acciones correctivas tomadas para verificar su efectividad e identificar cualquier deficiencia o debilidad.

Los resultados de las revisiones y acciones correctivas llevadas a cabo por los gerentes, propietarios de servicios, productos o información deben registrarse y estos registros deben mantenerse. Los gerentes deben informar los resultados a las personas que realizan las revisiones independientes (ver5.35) cuando se lleve a cabo una revisión independiente en el ámbito de su responsabilidad.

Las acciones correctivas deben completarse de manera oportuna según corresponda al riesgo. Si no se completa para la próxima revisión programada, el progreso debe al menos abordarse en esa revisión.

Otra información

El monitoreo operativo del uso del sistema está cubierto en8.15 ,8.16 ,8.17 .

5.37 Procedimientos operativos documentados

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo # Correctivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger #Recuperar	# Gestión de activos # Seguridad física # sistema_y_red- trabajo_seguridad #Aplicación_seguridad # configuración_segura #Identidad_y_acceso_ gestión # Threat_and_vulnera- bility_management # Continuidad # Information_securi- ty_event_management	# Gobernanza_y_ Ecosistema #Protec- ción # Defensa

Control

Los procedimientos operativos para las instalaciones de procesamiento de información deben documentarse y ponerse a disposición del personal que los necesite.

Objetivo

Garantizar el funcionamiento correcto y seguro de las instalaciones de procesamiento de información.

Guía

Se deben preparar procedimientos documentados para las actividades operativas de la organización asociadas con la seguridad de la información, por ejemplo:

- a) cuando la actividad deba ser realizada de la misma manera por muchas personas;
- b) cuando la actividad se realiza con poca frecuencia y cuando se realiza la próxima vez es probable que se haya olvidado el procedimiento;
- c) cuando la actividad sea nueva y presente un riesgo si no se realiza correctamente;
- d) antes del traspaso de la actividad al nuevo personal.

Los procedimientos operativos deben especificar:

- a) las personas responsables;
- b) la instalación y configuración segura de sistemas;
- c) procesamiento y manejo de información, tanto automatizado como manual;
- d) copia de seguridad (ver [8.13](#)) y resiliencia;
- e) requisitos de programación, incluidas las interdependencias con otros sistemas;
- f) instrucciones para el manejo de errores u otras condiciones excepcionales [por ejemplo, restricciones en el uso de programas de utilidad (ver [8.18](#))], que pueden surgir durante la ejecución del trabajo;
- g) contactos de soporte y escalamiento, incluidos contactos de soporte externo en caso de dificultades operativas o técnicas inesperadas;
- h) instrucciones de manejo de medios de almacenamiento (ver [7.10](#) y [7.14](#));
- i) procedimientos de reinicio y recuperación del sistema para su uso en caso de falla del sistema;

- j) la gestión de la pista de auditoría y la información de registro del sistema (ver8.15 y8.17) y sistemas de vigilancia por vídeo (ver7.4);
- k) procedimientos de seguimiento tales como capacidad, desempeño y seguridad (ver8.6 y8.16);
- l) instrucciones de mantenimiento.

Los procedimientos operativos documentados deben revisarse y actualizarse cuando sea necesario. Los cambios a los procedimientos operativos documentados deben ser autorizados. Cuando sea técnicamente factible, los sistemas de información deben administrarse de manera consistente, utilizando los mismos procedimientos, herramientas y utilidades.

Otra información

Ninguna otra información.

6 Controles de personas

6.1 Cribado

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Recursos humanos_ seguridad	# Gobernanza_y_ Ecosistema

Control

Los controles de verificación de antecedentes de todos los candidatos para convertirse en personal deben llevarse a cabo antes de unirse a la organización y de forma continua, teniendo en cuenta las leyes, reglamentos y ética aplicables, y ser proporcionales a los requisitos comerciales, la clasificación de la información a la que se accede y la riesgos percibidos.

Objetivo

Asegurar que todo el personal sea elegible y adecuado para las funciones para las que se le considera y siga siendo elegible y adecuado durante su empleo.

Guía

Se debe realizar un proceso de selección para todo el personal, incluido el personal a tiempo completo, a tiempo parcial y temporal. Cuando estas personas sean contratadas a través de proveedores de servicios, los requisitos de selección deben incluirse en los acuerdos contractuales entre la organización y los proveedores.

La información sobre todos los candidatos que se están considerando para puestos dentro de la organización debe recopilarse y manejarse teniendo en cuenta la legislación pertinente que exista en la jurisdicción correspondiente. En algunas jurisdicciones, la organización puede estar legalmente obligada a informar a los candidatos de antemano sobre las actividades de selección.

La verificación debe tener en cuenta toda la legislación relevante sobre privacidad, protección de PII y basada en el empleo y, cuando esté permitido, debe incluir lo siguiente:

- a) disponibilidad de referencias satisfactorias (por ejemplo, referencias comerciales y personales);
- b) una verificación (de integridad y exactitud) del currículum vitae del solicitante;
- c) confirmación de las calificaciones académicas y profesionales reclamadas;
- d) verificación de identidad independiente (por ejemplo, pasaporte u otro documento aceptable emitido por las autoridades correspondientes);

e) verificación más detallada, como revisión de crédito o revisión de antecedentes penales si el candidato asume un papel crítico.

Cuando se contrata a una persona para una función específica de seguridad de la información, la organización debe asegurarse de que el candidato:

- a) tiene la competencia necesaria para desempeñar la función de seguridad;
- b) se puede confiar para asumir el rol, especialmente si el rol es crítico para la organización.

Cuando un trabajo, ya sea en el nombramiento inicial o en la promoción, implique que la persona tenga acceso a instalaciones de procesamiento de información y, en particular, si esto implica el manejo de información confidencial (por ejemplo, información financiera, información personal o información de atención médica), la organización también debe considerar más, verificaciones más detalladas.

Los procedimientos deben definir los criterios y limitaciones para las revisiones de verificación (por ejemplo, quién es elegible para evaluar a las personas y cómo, cuándo y por qué se llevan a cabo las revisiones de verificación).

En situaciones en las que la verificación no se puede completar de manera oportuna, se deben implementar controles de mitigación hasta que se haya terminado la revisión, por ejemplo:

- a) incorporación retrasada;
- b) retraso en el despliegue de los activos corporativos;
- c) embarque con acceso reducido;
- d) terminación del empleo.

Los controles de verificación deben repetirse periódicamente para confirmar la idoneidad continua del personal, según la importancia del rol de una persona.

Otra información

Ninguna otra información.

6.2 Términos y condiciones de empleo

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Recursos humanos_ seguridad	# Gobernanza_y_ Ecosistema

Control

Los acuerdos contractuales de empleo deben establecer las responsabilidades del personal y de la organización para la seguridad de la información.

Objetivo

Asegurar que el personal comprenda sus responsabilidades de seguridad de la información para las funciones para las que se le considera.

Guía

Las obligaciones contractuales para el personal deben tener en cuenta la política de seguridad de la información de la organización y las políticas específicas del tema relevante. Además, se pueden aclarar y señalar los siguientes puntos:

- a) acuerdos de confidencialidad o de no divulgación que el personal al que se le da acceso a información confidencial debe firmar antes de que se le dé acceso a la información y otros activos asociados (ver [6.6](#));
- b) responsabilidades y derechos legales [por ejemplo, con respecto a las leyes de derechos de autor o la legislación de protección de datos (ver [5.32](#) y [5.34](#))];
- c) responsabilidades para la clasificación de la información y la gestión de la información de la organización y otros activos asociados, instalaciones de procesamiento de información y servicios de información manejados por el personal (ver [5.9](#) a [5.13](#));
- d) responsabilidades por el tratamiento de la información recibida de los interesados;
- e) acciones a tomar si el personal ignora los requisitos de seguridad de la organización (ver [6.4](#)).

Las funciones y responsabilidades de seguridad de la información deben comunicarse a los candidatos durante el proceso previo al empleo.

La organización debe asegurarse de que el personal esté de acuerdo con los términos y condiciones relacionados con la seguridad de la información. Estos términos y condiciones deben ser apropiados para la naturaleza y el grado de acceso que tendrán a los activos de la organización asociados con los sistemas y servicios de información. Los términos y condiciones relacionados con la seguridad de la información deben revisarse cuando cambien las leyes, los reglamentos, la política de seguridad de la información o las políticas específicas de un tema.

En su caso, las responsabilidades contenidas en los términos y condiciones de empleo deben continuar durante un período definido después de la terminación del empleo (ver [6.5](#)).

Otra información

Se puede utilizar un código de conducta para establecer las responsabilidades de seguridad de la información del personal con respecto a la confidencialidad, la protección de la PII, la ética, el uso apropiado de la información de la organización y otros activos asociados, así como las prácticas respetables esperadas por la organización.

Se puede exigir a una parte externa, con la que está asociado el personal del proveedor, que celebre acuerdos contractuales en nombre de la persona contratada.

Si la organización no es una entidad legal y no tiene empleados, se puede considerar el equivalente de un acuerdo contractual y términos y condiciones de acuerdo con la orientación de este control.

6.3 Concientización, educación y capacitación en seguridad de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Recursos humanos_ seguridad	# Gobernanza_y_ Ecosistema

Control

El personal de la organización y las partes interesadas relevantes deben recibir la conciencia, educación y capacitación adecuadas en seguridad de la información y actualizaciones periódicas de la política de seguridad de la información de la organización, las políticas y los procedimientos específicos del tema, según sea relevante para su función laboral.

Objetivo

Asegurar que el personal y las partes interesadas relevantes conozcan y cumplan con sus responsabilidades de seguridad de la información.

Guía

General

Se debe establecer un programa de concientización, educación y capacitación en seguridad de la información de acuerdo con la política de seguridad de la información de la organización, las políticas específicas del tema y los procedimientos relevantes sobre seguridad de la información, teniendo en cuenta la información de la organización que debe protegerse y los controles de seguridad de la información que se han implementado para proteger la información.

La concientización, la educación y la capacitación en seguridad de la información deben llevarse a cabo periódicamente. La concientización, la educación y la capacitación iniciales pueden aplicarse al personal nuevo y a aquellos que se transfieran a nuevos puestos o roles con requisitos de seguridad de la información sustancialmente diferentes.

La comprensión del personal debe evaluarse al final de una actividad de sensibilización, educación o formación para probar la transferencia de conocimientos y la eficacia del programa de sensibilización, educación y formación.

Conciencia

Un programa de concientización sobre la seguridad de la información debe tener como objetivo que el personal sea consciente de sus responsabilidades con respecto a la seguridad de la información y los medios por los cuales se cumplen esas responsabilidades.

El programa de sensibilización debe planificarse teniendo en cuenta las funciones del personal de la organización, incluido el personal interno y externo (por ejemplo, consultores externos, personal del proveedor). Las actividades del programa de concientización deben programarse a lo largo del tiempo, preferiblemente con regularidad, para que las actividades se repitan y cubran al personal nuevo. También debe basarse en las lecciones aprendidas de los incidentes de seguridad de la información.

El programa de sensibilización debe incluir una serie de actividades de sensibilización a través de canales físicos o virtuales adecuados, como campañas, folletos, carteles, boletines, sitios web, sesiones informativas, sesiones informativas, módulos de aprendizaje electrónico y correos electrónicos.

La concientización sobre la seguridad de la información debe cubrir aspectos generales tales como:

- a) el compromiso de la dirección con la seguridad de la información en toda la organización;
- b) las necesidades de familiarización y cumplimiento con respecto a las normas y obligaciones de seguridad de la información aplicables, teniendo en cuenta la política de seguridad de la información y las políticas, estándares, leyes, estatutos, reglamentos, contratos y acuerdos específicos del tema;
- c) responsabilidad personal por las propias acciones e inacciones, y responsabilidades generales para asegurar o proteger la información que pertenece a la organización y las partes interesadas;
- d) procedimientos básicos de seguridad de la información [por ejemplo, informes de eventos de seguridad de la información (6.8)] y controles básicos [por ejemplo, seguridad de contraseña (5.17)];
- e) puntos de contacto y recursos para obtener información adicional y asesoramiento sobre asuntos de seguridad de la información, incluidos más materiales de concientización sobre la seguridad de la información.

Educación y entrenamiento

La organización debe identificar, preparar e implementar un plan de capacitación adecuado para los equipos técnicos cuyas funciones requieren conjuntos de habilidades y experiencia específicos. Los equipos técnicos deben tener las habilidades para configurar y mantener el nivel de seguridad requerido para dispositivos, sistemas, aplicaciones y servicios. Si faltan habilidades, la organización debe tomar medidas y adquirirlas.

El programa de educación y capacitación debe considerar diferentes formas [por ejemplo, conferencias o autoestudios, ser asesorado por personal experto o consultores (capacitación en el trabajo), rotar a los miembros del personal para seguir diferentes actividades, reclutar personas ya capacitadas y contratar consultores]. Puede usar diferentes medios de entrega, incluidos el aprendizaje en el aula, a distancia, basado en la web, a su propio ritmo y otros. El personal técnico debe mantener actualizados sus conocimientos suscribiéndose a boletines y revistas o asistiendo a congresos y eventos destinados a la mejora técnica y profesional.

Otra información

Al redactar un programa de concientización, es importante no solo centrarse en el 'qué' y el 'cómo', sino también en el 'por qué', cuando sea posible. Es importante que el personal comprenda el objetivo de la seguridad de la información y el efecto potencial, positivo y negativo, sobre la organización de su propio comportamiento.

La concientización, la educación y la capacitación en seguridad de la información pueden ser parte de, o llevarse a cabo en colaboración con otras actividades, por ejemplo, administración general de la información, TIC, seguridad, privacidad o capacitación en seguridad.

6.4 Proceso disciplinario

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo #Cor- correctivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger #Responder	# Recursos humanos_ seguridad	# Gobernanza_y_ Ecosistema

Control

Se debe formalizar y comunicar un proceso disciplinario para tomar acciones contra el personal y otras partes interesadas relevantes que hayan cometido una violación de la política de seguridad de la información.

Objetivo

Asegurar que el personal y otras partes interesadas relevantes entiendan las consecuencias de la violación de la política de seguridad de la información, para disuadir y tratar adecuadamente al personal y otras partes interesadas relevantes que cometieron la violación.

Guía

El proceso disciplinario no debe iniciarse sin la verificación previa de que se ha producido una violación de la política de seguridad de la información (ver [5.28](#)).

El proceso disciplinario formal debe prever una respuesta graduada que tenga en cuenta factores tales como:

- a) la naturaleza (quién, qué, cuándo, cómo) y la gravedad del incumplimiento y sus consecuencias;
- b) si el delito fue intencional (malicioso) o no intencional (accidental);
- c) si se trata o no de una primera o reiterada infracción;
- d) si el infractor fue debidamente capacitado o no.

La respuesta debe tener en cuenta los requisitos legales, estatutarios, reglamentarios, contractuales y comerciales pertinentes, así como otros factores que sean necesarios. El proceso disciplinario también debe usarse como elemento disuasorio para evitar que el personal y otras partes interesadas relevantes violen la política de seguridad de la información, las políticas y los procedimientos específicos del tema para la seguridad de la información. Las violaciones deliberadas de la política de seguridad de la información pueden requerir acciones inmediatas.

Otra información

Siempre que sea posible, la identidad de las personas sujetas a medidas disciplinarias debe protegerse de conformidad con los requisitos aplicables.

Cuando las personas demuestran un comportamiento excelente con respecto a la seguridad de la información, pueden ser recompensadas para promover la seguridad de la información y fomentar el buen comportamiento.

6.5 Responsabilidades después de la terminación o cambio de empleo

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Recursos humanos_ seguridad # Gestión de activos	# Gobernanza_y_ Ecosistema

Control

Las responsabilidades y deberes de seguridad de la información que siguen siendo válidos después de la terminación o el cambio de empleo deben definirse, aplicarse y comunicarse al personal pertinente y otras partes interesadas.

Objetivo

Para proteger los intereses de la organización como parte del proceso de cambio o terminación de empleo o contratos.

Guía

El proceso para gestionar la terminación o el cambio de empleo debe definir qué responsabilidades y deberes de seguridad de la información deben permanecer vigentes después de la terminación o el cambio. Esto puede incluir la confidencialidad de la información, la propiedad intelectual y otros conocimientos obtenidos, así como las responsabilidades contenidas en cualquier otro acuerdo de confidencialidad (ver [6.6](#)). Las responsabilidades y deberes que sigan siendo válidos después de la terminación del empleo o del contrato deben figurar en los términos y condiciones de empleo de la persona (ver [6.2](#)), contrato o acuerdo. Otros contratos o acuerdos que continúan por un período definido después del final del empleo del individuo también pueden contener responsabilidades de seguridad de la información.

Los cambios de responsabilidad o empleo deben gestionarse como la terminación de la responsabilidad o empleo actual combinada con el inicio de la nueva responsabilidad o empleo.

Las funciones y responsabilidades de seguridad de la información que tenga cualquier persona que deje o cambie de puesto deben identificarse y transferirse a otra persona.

Debe establecerse un proceso para la comunicación de los cambios y de los procedimientos operativos al personal, otras partes interesadas y personas de contacto pertinentes (por ejemplo, clientes y proveedores).

El proceso de terminación o cambio de empleo también debe aplicarse al personal externo (es decir, proveedores) cuando se produzca una terminación del personal, del contrato o del puesto con la organización, o cuando haya un cambio de puesto dentro de la organización.

Otra información

En muchas organizaciones, la función de recursos humanos generalmente es responsable del proceso general de terminación y trabaja junto con el gerente supervisor de la persona en transición para administrar los aspectos de seguridad de la información de los procedimientos relevantes. En el caso de personal proporcionado a través de una parte externa (por ejemplo, a través de un proveedor), este proceso de terminación lo realiza la parte externa de acuerdo con el contrato entre la organización y la parte externa.

6.6 Acuerdos de confidencialidad o no divulgación

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad	# Proteger	# Recursos_humanos_seguridad # Información_protección # relaciones_con_proveedores	# Gobernanza_y_ Ecosistema

Control

Los acuerdos de confidencialidad o no divulgación que reflejen las necesidades de la organización para la protección de la información deben ser identificados, documentados, revisados regularmente y firmados por el personal y otras partes interesadas relevantes.

Objetivo

Para mantener la confidencialidad de la información accesible por el personal o partes externas.

Guía

Los acuerdos de confidencialidad o de no divulgación deben abordar el requisito de proteger la información confidencial utilizando términos legalmente exigibles. Los acuerdos de confidencialidad o no divulgación son aplicables a las partes interesadas y al personal de la organización. En función de los requisitos de seguridad de la información de una organización, los términos de los acuerdos deben determinarse teniendo en cuenta el tipo de información que se manejará, su nivel de clasificación, su uso y el acceso permitido por la otra parte. Para identificar los requisitos para los acuerdos de confidencialidad o no divulgación, se deben considerar los siguientes elementos:

- a) una definición de la información a proteger (por ejemplo, información confidencial);
- b) la duración esperada de un acuerdo, incluidos los casos en que puede ser necesario mantener la confidencialidad indefinidamente o hasta que la información esté disponible públicamente;
- c) las acciones requeridas cuando se termina un acuerdo;
- d) las responsabilidades y acciones de los signatarios para evitar la divulgación de información no autorizada;
- e) la propiedad de la información, los secretos comerciales y la propiedad intelectual, y cómo esto se relaciona con la protección de la información confidencial;
- f) el uso permitido de la información confidencial y los derechos del firmante para usar la información;
- g) el derecho a auditar y monitorear actividades que involucren información confidencial para circunstancias altamente sensibles;
- h) el proceso de notificación y reporte de divulgación no autorizada o fuga de información confidencial;
- i) los términos para la devolución o destrucción de la información al término del contrato;
- j) las acciones previstas a tomar en caso de incumplimiento del acuerdo.

La organización debe tener en cuenta el cumplimiento de los acuerdos de confidencialidad y no divulgación para la jurisdicción a la que se aplican (ver [5.31](#), [5.32](#), [5.33](#), [5.34](#)).

Los requisitos para los acuerdos de confidencialidad y no divulgación deben revisarse periódicamente y cuando ocurran cambios que influyan en estos requisitos.

Otra información

Los acuerdos de confidencialidad y no divulgación protegen la información de la organización e informan a los signatarios de su responsabilidad de proteger, usar y divulgar la información de manera responsable y autorizada.

6.7 Trabajo a distancia

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Gestión de activos # Information_protec- ción # Seguridad física # sistema_y_red- trabajo_seguridad	# Protección

Control

Se deben implementar medidas de seguridad cuando el personal trabaja de forma remota para proteger la información a la que se accede, procesa o almacena fuera de las instalaciones de la organización.

Objetivo

Para garantizar la seguridad de la información cuando el personal está trabajando de forma remota.

Guía

El trabajo remoto ocurre cuando el personal de la organización trabaja desde una ubicación fuera de las instalaciones de la organización, accediendo a la información ya sea en forma impresa o electrónica a través de equipos de TIC. Los entornos de trabajo remoto incluyen los denominados "teletrabajo", "teletrabajo", "lugar de trabajo flexible", "entornos de trabajo virtuales" y "mantenimiento remoto".

NOTA Es posible que no todas las recomendaciones de esta guía se puedan aplicar debido a la legislación local y regulaciones en diferentes jurisdicciones.

Las organizaciones que permiten actividades de trabajo a distancia deben emitir una política específica sobre el tema del trabajo a distancia que defina las condiciones y restricciones pertinentes. Cuando se considere aplicable, se deben considerar los siguientes asuntos:

- a) la seguridad física existente o propuesta del sitio de trabajo remoto, teniendo en cuenta la seguridad física del lugar y el entorno local, incluidas las diferentes jurisdicciones donde se encuentra el personal;
- b) reglas y mecanismos de seguridad para el entorno físico remoto, como archivadores con cerradura, transporte seguro entre ubicaciones y reglas para el acceso remoto, escritorio despejado, impresión y eliminación de información y otros activos asociados, e informes de eventos de seguridad de la información (ver [6.8](#));
- c) los entornos físicos de trabajo remoto esperados;
- d) los requisitos de seguridad de las comunicaciones, teniendo en cuenta la necesidad de acceso remoto a los sistemas de la organización, la sensibilidad de la información a la que se accederá y pasará por el enlace de comunicación y la sensibilidad de los sistemas y aplicaciones;
- e) el uso de acceso remoto, como acceso de escritorio virtual que admita el procesamiento y almacenamiento de información en equipos de propiedad privada;
- f) la amenaza de acceso no autorizado a información o recursos de otras personas en el lugar de trabajo remoto (por ejemplo, familiares y amigos);
- g) la amenaza de acceso no autorizado a información o recursos de otras personas en lugares públicos;
- h) el uso de redes domiciliarias y redes públicas, y requisitos o restricciones en la configuración de servicios de redes inalámbricas;
- i) uso de medidas de seguridad, como firewalls y protección contra malware;

- j) mecanismos seguros para implementar e inicializar sistemas de forma remota;
- k) mecanismos seguros de autenticación y habilitación de privilegios de acceso teniendo en cuenta la vulnerabilidad de los mecanismos de autenticación de un solo factor donde se permite el acceso remoto a la red de la organización.

Las directrices y medidas a considerar deben incluir:

- a) la provisión de equipos y muebles de almacenamiento adecuados para las actividades de trabajo remoto, donde no se permite el uso de equipos de propiedad privada que no estén bajo el control de la organización;
- b) una definición del trabajo permitido, la clasificación de la información que puede ser mantenida y los sistemas y servicios internos a los que el trabajador remoto está autorizado a acceder;
- c) la provisión de capacitación para quienes trabajan a distancia y quienes brindan apoyo. Esto debe incluir cómo realizar negocios de manera segura mientras se trabaja de forma remota;
- d) la provisión de equipos de comunicación adecuados, incluidos los métodos para asegurar el acceso remoto, como los requisitos sobre bloqueos de pantalla del dispositivo y temporizadores de inactividad; la habilitación del seguimiento de la ubicación del dispositivo; instalación de capacidades de borrado remoto;
- e) seguridad física;
- f) reglas y orientación sobre el acceso de familiares y visitantes a equipos e información;
- g) la provisión de soporte y mantenimiento de hardware y software;
- h) la provisión de seguros;
- i) los procedimientos de respaldo y continuidad del negocio;
- j) auditoría y seguimiento de la seguridad;
- k) revocación de facultades y derechos de acceso y devolución de equipos cuando finalicen las actividades de trabajo a distancia.

Otra información

Ninguna otra información.

6.8 Reporte de eventos de seguridad de la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Detective	# Confidencialidad # Integridad # Disponibilidad	# Detectar	# Information_security_event_management	# Defensa

Control

La organización debe proporcionar un mecanismo para que el personal informe eventos de seguridad de la información observados o sospechados a través de los canales apropiados de manera oportuna.

Objetivo

Para respaldar la notificación oportuna, coherente y eficaz de los eventos de seguridad de la información que puedan ser identificados por el personal.

Guía

Todo el personal y los usuarios deben ser conscientes de su responsabilidad de informar los eventos de seguridad de la información lo más rápido posible para prevenir o minimizar el efecto de los incidentes de seguridad de la información.

También deben conocer el procedimiento para informar eventos de seguridad de la información y el punto de contacto al que se deben informar los eventos. El mecanismo de presentación de informes debe ser lo más fácil, accesible y disponible posible. Los eventos de seguridad de la información incluyen incidentes, violaciones y vulnerabilidades.

Las situaciones a considerar para el reporte de eventos de seguridad de la información incluyen:

- a) controles de seguridad de la información ineficaces;
- b) incumplimiento de las expectativas de confidencialidad, integridad o disponibilidad de la información;
- c) errores humanos;
- d) incumplimiento de la política de seguridad de la información, políticas específicas del tema o normas aplicables;
- e) incumplimientos de las medidas de seguridad física;
- f) cambios del sistema que no han pasado por el proceso de gestión de cambios;
- g) mal funcionamiento u otro comportamiento anómalo del sistema de software o hardware;
- h) infracciones de acceso;
- i) vulnerabilidades;
- j) sospecha de infección por malware.

Se debe advertir al personal y a los usuarios que no intenten probar vulnerabilidades de seguridad de la información sospechosas. Las vulnerabilidades de prueba pueden interpretarse como un mal uso potencial del sistema y también pueden causar daños al sistema o servicio de información, y pueden corromper u ocultar la evidencia digital. En última instancia, esto puede resultar en responsabilidad legal para la persona que realiza la prueba.

Otra información

Consulte la serie ISO/IEC 27035 para obtener información adicional.

7 controles físicos

7.1 Perímetros de seguridad física

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Seguridad física	# Protección

Control

Los perímetros de seguridad deben definirse y utilizarse para proteger las áreas que contienen información y otros activos asociados.

Objetivo

Para evitar el acceso físico no autorizado, el daño y la interferencia a la información de la organización y otros activos asociados.

Guía

Las siguientes pautas deben considerarse e implementarse cuando corresponda para los perímetros de seguridad física:

- a) definir los perímetros de seguridad y la ubicación y fortaleza de cada uno de los perímetros de acuerdo con los requisitos de seguridad de la información relacionados con los activos dentro del perímetro;

- b) tener perímetros físicamente sólidos para un edificio o sitio que contenga instalaciones de procesamiento de información (es decir, no debe haber espacios en el perímetro o áreas donde pueda ocurrir fácilmente un allanamiento).
Los techos, paredes, techos y pisos exteriores del sitio deben ser de construcción sólida y todas las puertas externas deben estar adecuadamente protegidas contra el acceso no autorizado con mecanismos de control (por ejemplo, rejas, alarmas, cerraduras). Las puertas y ventanas deben cerrarse con llave cuando estén desatendidas y se debe considerar la protección externa para las ventanas, particularmente a nivel del suelo; también se deben considerar los puntos de ventilación;
- c) alarmar, monitorear y probar todas las puertas contra incendios en un perímetro de seguridad junto con las paredes para establecer el nivel requerido de resistencia de acuerdo con los estándares adecuados. Deben operar de manera a prueba de fallas.

Otra información

La protección física se puede lograr mediante la creación de una o más barreras físicas alrededor de las instalaciones de la organización y las instalaciones de procesamiento de información.

Un área segura puede ser una oficina con cerradura o varias habitaciones rodeadas por una barrera de seguridad física interna continua. Pueden ser necesarias barreras y perímetros adicionales para controlar el acceso físico entre áreas con diferentes requisitos de seguridad dentro del perímetro de seguridad. La organización debe considerar tener medidas de seguridad física que puedan fortalecerse durante situaciones de mayor amenaza.

7.2 Entrada física

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Seguridad física # Identity_and_Access_Management	# Protección

Control

Las áreas seguras deben estar protegidas por controles de entrada y puntos de acceso apropiados.

Objetivo

Para garantizar que solo se produzca el acceso físico autorizado a la información de la organización y otros activos asociados.

Guía

General

Los puntos de acceso como las áreas de entrega y carga y otros puntos donde personas no autorizadas pueden ingresar a las instalaciones deben controlarse y, si es posible, aislarse de las instalaciones de procesamiento de información para evitar el acceso no autorizado.

Se deben considerar las siguientes pautas:

- a) restringir el acceso a los sitios y edificios solo al personal autorizado. El proceso de gestión de los derechos de acceso a las áreas físicas debe incluir el otorgamiento, revisión periódica, actualización y revocación de las autorizaciones (ver [5.18](#));
- b) mantener y monitorear de forma segura un libro de registro físico o un registro de auditoría electrónico de todos los accesos y proteger todos los registros (ver [5.33](#)) e información confidencial de autenticación;
- c) establecer e implementar un proceso y mecanismos técnicos para la gestión del acceso a las áreas donde se procesa o almacena la información. Los mecanismos de autenticación incluyen el uso de tarjetas de acceso, biometría o autenticación de dos factores, como una tarjeta de acceso y un PIN secreto. Se deben considerar puertas dobles de seguridad para el acceso a áreas sensibles;

d) establecer un área de recepción monitoreada por personal u otros medios para controlar el acceso físico al sitio o edificio;

e) inspeccionar y examinar los efectos personales del personal y de los interesados a la entrada y salida;

NOTA Puede existir legislación y reglamentos locales con respecto a la posibilidad de inspeccionar pertenencias.

f) requerir que todo el personal y las partes interesadas usen algún tipo de identificación visible y que notifiquen de inmediato al personal de seguridad si encuentran visitantes sin escolta y cualquier persona que no use una identificación visible. Se deben considerar insignias fácilmente distinguibles para identificar mejor a los empleados permanentes, proveedores y visitantes;

g) otorgar acceso restringido al personal del proveedor a áreas seguras o instalaciones de procesamiento de información solo cuando sea necesario. Este acceso debe ser autorizado y monitoreado;

h) prestar especial atención a la seguridad del acceso físico en el caso de edificios que contengan activos para múltiples organizaciones;

i) diseñar medidas de seguridad física para que puedan reforzarse cuando aumente la probabilidad de incidentes físicos;

j) proteger otros puntos de entrada, como salidas de emergencia, del acceso no autorizado;

k) establecer un proceso de gestión de claves para garantizar la gestión de las claves físicas o la información de autenticación (p. ej., códigos de bloqueo, cerraduras de combinación para oficinas, habitaciones e instalaciones, como armarios de llaves) y garantizar un libro de registro o una auditoría anual de claves y que el acceso a claves físicas o se controla la información de autenticación (ver [5.17](#) para obtener más orientación sobre la información de autenticación).

Visitantes

Se deben considerar las siguientes pautas:

a) autenticar la identidad de los visitantes por un medio apropiado;

b) registrar la fecha y hora de entrada y salida de los visitantes;

c) permitir el acceso de visitantes únicamente para fines específicos, autorizados y con instrucciones sobre los requisitos de seguridad del área y sobre los procedimientos de emergencia;

d) supervisar a todos los visitantes, a menos que se conceda una excepción explícita.

Zonas de entrega y carga y entrada de material

Se deben considerar las siguientes pautas:

a) restringir el acceso a las áreas de entrega y carga desde el exterior del edificio al personal identificado y autorizado;

b) diseñar las áreas de entrega y carga para que las entregas puedan cargarse y descargarse sin que el personal de entrega obtenga acceso no autorizado a otras partes del edificio;

c) asegurar las puertas externas de las áreas de entrega y carga cuando se abren las puertas de las áreas restringidas;

d) inspeccionar y examinar las entregas entrantes en busca de explosivos, productos químicos u otros materiales peligrosos antes de que se muevan de las áreas de entrega y carga;

e) registrar las entregas entrantes de acuerdo con los procedimientos de gestión de activos (ver [5.9](#) y [7.10](#)) al ingresar al sitio;

- f) separar físicamente los envíos entrantes y salientes, cuando sea posible;
- g) inspeccionar las entregas entrantes en busca de evidencia de manipulación en el camino. Si se descubre una manipulación, se debe informar de inmediato al personal de seguridad.

Otra información

Ninguna otra información.

7.3 Aseguramiento de oficinas, salas e instalaciones

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Seguridad física # Gestión de activos	# Protección

Control

Debe diseñarse e implementarse la seguridad física de las oficinas, salas e instalaciones.

Objetivo

Prevenir el acceso físico no autorizado, el daño y la interferencia a la información de la organización y otros activos asociados en las oficinas, salas e instalaciones.

Guía

Se deben considerar las siguientes pautas para asegurar oficinas, salas e instalaciones:

- ubicar las instalaciones críticas para evitar el acceso del público;
- cuando corresponda, asegurarse de que los edificios sean discretos y den una indicación mínima de su propósito, sin señales obvias, fuera o dentro del edificio, que identifiquen la presencia de actividades de procesamiento de información;
- configurar instalaciones para evitar que la información o actividades confidenciales sean visibles y audibles desde el exterior. El blindaje electromagnético también debe considerarse apropiado;
- no poner a disposición de cualquier persona no autorizada directorios, guías telefónicas internas y mapas accesibles en línea que identifiquen ubicaciones de instalaciones de procesamiento de información confidencial.

Otra información

Ninguna otra información.

7.4 Supervisión de la seguridad física

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo # Detectivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger # Detectar	# Seguridad física	# Protección # Defensa

Control

Las instalaciones deben ser monitoreadas continuamente para detectar accesos físicos no autorizados.

Objetivo

Para detectar y disuadir el acceso físico no autorizado.

Guía

Las instalaciones físicas deben ser monitoreadas por sistemas de vigilancia, que pueden incluir guardias, alarmas contra intrusos, sistemas de monitoreo de video como un circuito cerrado de televisión y software de gestión de información de seguridad física, ya sea administrado internamente o por un proveedor de servicios de monitoreo.

El acceso a los edificios que albergan sistemas críticos debe monitorearse continuamente para detectar accesos no autorizados o comportamientos sospechosos mediante:

- a) instalar sistemas de vigilancia por video, como un circuito cerrado de televisión, para ver y registrar el acceso a áreas sensibles dentro y fuera de las instalaciones de una organización;
- b) instalar, de acuerdo con las normas pertinentes aplicables, y probar periódicamente detectores de contacto, sonido o movimiento para activar una alarma de intrusión, tales como:
 - 1) instalar detectores de contacto que activen una alarma cuando se haga o se rompa un contacto en cualquier lugar donde se pueda hacer o romper un contacto (como ventanas y puertas y debajo de objetos) para ser utilizado como alarma de pánico;
 - 2) detectores de movimiento basados en tecnología infrarroja que activan una alarma cuando un objeto pasa por su campo de visión;
 - 3) instalar sensores sensibles al sonido de cristales rotos que puedan usarse para activar una alarma para alertar al personal de seguridad;
- c) usar esas alarmas para cubrir todas las puertas exteriores y ventanas accesibles. Las áreas desocupadas deben estar alarmadas en todo momento; también se debe proporcionar cobertura para otras áreas (por ejemplo, salas de computadoras o de comunicaciones).

El diseño de los sistemas de monitoreo debe mantenerse confidencial porque la divulgación puede facilitar robos no detectados.

Los sistemas de monitoreo deben protegerse contra el acceso no autorizado para evitar que personas no autorizadas accedan a la información de vigilancia, como transmisiones de video, o que los sistemas se deshabiliten de forma remota.

El panel de control del sistema de alarma debe colocarse en una zona de alarma y, para las alarmas de seguridad, en un lugar que permita una ruta de salida fácil para la persona que activa la alarma. El panel de control y los detectores deben tener mecanismos a prueba de manipulaciones. El sistema debe probarse periódicamente para asegurarse de que funciona según lo previsto, especialmente si sus componentes funcionan con baterías.

Cualquier mecanismo de monitoreo y grabación debe usarse teniendo en cuenta las leyes y regulaciones locales, incluida la legislación de protección de datos y PII, especialmente con respecto al monitoreo del personal y los períodos de retención de videos grabados.

Otra información

Ninguna otra información.

7.5 Protección contra amenazas físicas y ambientales

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Seguridad física	# Protección

Control

Se debe diseñar e implementar la protección contra amenazas físicas y ambientales, como desastres naturales y otras amenazas físicas intencionales o no intencionales a la infraestructura.

Objetivo

Prevenir o reducir las consecuencias de eventos originados por amenazas físicas y ambientales.

Guía

Las evaluaciones de riesgos para identificar las posibles consecuencias de las amenazas físicas y ambientales deben realizarse antes de comenzar las operaciones críticas en un sitio físico y en intervalos regulares. Se deben implementar las salvaguardas necesarias y se deben monitorear los cambios en las amenazas. Debe obtenerse asesoramiento especializado sobre cómo gestionar los riesgos derivados de amenazas físicas y ambientales como incendios, inundaciones, terremotos, explosiones, disturbios civiles, desechos tóxicos, emisiones ambientales y otras formas de desastres naturales o desastres causados por seres humanos.

La ubicación y la construcción de las instalaciones físicas deben tener en cuenta:

- a) topografía local, como elevación adecuada, masas de agua y fallas tectónicas;
- b) amenazas urbanas, como lugares con un alto perfil para atraer disturbios políticos, actividad criminal o ataques terroristas.

Con base en los resultados de la evaluación de riesgos, se deben identificar las amenazas físicas y ambientales relevantes y se deben considerar los controles apropiados en los siguientes contextos como ejemplos:

- a) incendio: instalar y configurar sistemas capaces de detectar incendios en una etapa temprana para enviar alarmas o activar sistemas de extinción de incendios para evitar daños por incendios en los medios de almacenamiento y en los sistemas de procesamiento de información relacionados. La supresión de incendios debe realizarse utilizando la sustancia más apropiada en relación con el entorno circundante (por ejemplo, gas en espacios confinados);
- b) inundaciones: instalar sistemas capaces de detectar inundaciones en una etapa temprana debajo de los pisos de áreas que contienen medios de almacenamiento o sistemas de procesamiento de información. Las bombas de agua o medios equivalentes deberían estar fácilmente disponibles en caso de que ocurra una inundación;
- c) sobretensiones eléctricas: adoptar sistemas capaces de proteger los sistemas de información del servidor y del cliente contra sobretensiones eléctricas o eventos similares para minimizar las consecuencias de tales eventos;
- d) explosivos y armas: realizar inspecciones aleatorias para detectar la presencia de explosivos o armas en el personal, vehículos o bienes que ingresan a las instalaciones de procesamiento de información sensible.

Otra información

Las cajas fuertes u otras formas de instalaciones de almacenamiento seguras pueden proteger la información almacenada en ellas contra desastres como incendios, terremotos, inundaciones o explosiones.

Las organizaciones pueden considerar los conceptos de prevención del delito a través del diseño ambiental al diseñar los controles para asegurar su entorno y reducir las amenazas urbanas. Por ejemplo, en lugar de utilizar bolardos, las estatuas o los elementos de agua pueden servir como elemento y barrera física.

7.6 Trabajar en áreas seguras

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Seguridad física	# Protección

Control

Se deben diseñar e implementar medidas de seguridad para trabajar en áreas seguras.

Objetivo

Para proteger la información y otros activos asociados en áreas seguras contra daños e interferencias no autorizadas por parte del personal que trabaja en estas áreas.

Guía

Las medidas de seguridad para trabajar en áreas seguras deben aplicarse a todo el personal y cubrir todas las actividades que se desarrollen en el área segura.

Se deben considerar las siguientes pautas:

- a) hacer que el personal sea consciente de la existencia o de las actividades dentro de un área segura solo según sea necesario;
- b) evitar el trabajo sin supervisión en áreas seguras tanto por razones de seguridad como para reducir las posibilidades de actividades maliciosas;
- c) cerrar físicamente e inspeccionar periódicamente las áreas seguras vacantes;
- d) no permitir equipos fotográficos, de video, de audio u otros equipos de grabación, como cámaras en los dispositivos terminales de los usuarios, a menos que estén autorizados;
- e) controlar adecuadamente el transporte y uso de los dispositivos de punto final del usuario en áreas seguras;
- f) publicar los procedimientos de emergencia de manera fácilmente visible o accesible.

Otra información

Ninguna otra información.

7.7 Escritorio despejado y pantalla despejada

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad	# Proteger	# Seguridad física	# Protección

Control

Deben definirse y aplicarse adecuadamente reglas de escritorio limpio para documentos y medios de almacenamiento extraíbles y reglas de pantalla limpia para las instalaciones de procesamiento de información.

Objetivo

Reducir los riesgos de acceso no autorizado, pérdida y daño de la información en escritorios, pantallas y en otros lugares accesibles durante y fuera del horario normal de trabajo.

Guía

La organización debe establecer y comunicar una política específica del tema sobre escritorio despejado y pantalla despejada a todas las partes interesadas relevantes.

Se deben considerar las siguientes pautas:

- a) guardar bajo llave la información comercial sensible o crítica (por ejemplo, en papel o en medios de almacenamiento electrónicos) (idealmente en una caja fuerte, gabinete u otra forma de mueble de seguridad) cuando no se requiera, especialmente cuando la oficina esté desocupada;
- b) proteger los dispositivos de punto final del usuario mediante cerraduras con llave u otros medios de seguridad cuando no estén en uso o desatendidos;

- c) dejar los dispositivos de punto final de usuario desconectados o protegidos con un mecanismo de bloqueo de pantalla y teclado controlado por un mecanismo de autenticación de usuario cuando están desatendidos. Todas las computadoras y sistemas deben configurarse con una función de tiempo de espera o cierre de sesión automático;
- d) hacer que el originador recopile los resultados de las impresoras o dispositivos multifunción de inmediato. El uso de impresoras con una función de autenticación, de modo que los creadores sean los únicos que puedan obtener sus impresiones y solo cuando estén parados al lado de la impresora;
- e) almacenar de forma segura documentos y medios de almacenamiento extraíbles que contengan información confidencial y, cuando ya no se necesiten, desecharlos utilizando mecanismos seguros de eliminación;
- f) establecer y comunicar reglas y orientación para la configuración de ventanas emergentes en las pantallas (p. ej., apagar las nuevas ventanas emergentes de correo electrónico y mensajería, si es posible, durante presentaciones, pantallas compartidas o en un área pública);
- g) borrar información sensible o crítica en pizarras y otros tipos de pantallas cuando ya no se necesiten.

La organización debe tener procedimientos implementados al desocupar las instalaciones, incluida la realización de un barrido final antes de irse para garantizar que los activos de la organización no se queden atrás (por ejemplo, documentos caídos detrás de cajones o muebles).

Otra información

Ninguna otra información.

7.8 Ubicación y protección del equipo

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Seguridad física # Gestión de activos	# Protección

Control

El equipo debe estar ubicado de forma segura y protegida.

Objetivo

Reducir los riesgos de amenazas físicas y ambientales, y de accesos y daños no autorizados.

Guía

Se deben considerar las siguientes pautas para proteger el equipo:

- a) ubicar el equipo para minimizar el acceso innecesario a las áreas de trabajo y evitar el acceso no autorizado;
- b) ubicar cuidadosamente las instalaciones de procesamiento de información que manejan datos confidenciales para reducir el riesgo de que personas no autorizadas vean la información durante su uso;
- c) adoptar controles para minimizar el riesgo de posibles amenazas físicas y ambientales [por ejemplo, robo, incendio, explosivos, humo, agua (o falla en el suministro de agua), polvo, vibración, efectos químicos, interferencia en el suministro eléctrico, interferencia en las comunicaciones, radiación electromagnética y vandalismo];
- d) establecer pautas para comer, beber y fumar en las proximidades de las instalaciones de procesamiento de información;
- e) monitorear las condiciones ambientales, como la temperatura y la humedad, en busca de condiciones que puedan afectar negativamente la operación de las instalaciones de procesamiento de información;

- f) aplicar protección contra rayos a todos los edificios y colocar filtros de protección contra rayos en todas las líneas eléctricas y de comunicaciones entrantes;
- g) considerar el uso de métodos de protección especiales, como membranas de teclado, para equipos en ambientes industriales;
- h) proteger los equipos que procesan información confidencial para minimizar el riesgo de fuga de información debido a la emanación electromagnética;
- i) separar físicamente las instalaciones de procesamiento de información gestionadas por la organización de aquellas que no son gestionadas por la organización.

Otra información

Ninguna otra información.

7.9 Seguridad de los activos fuera de las instalaciones

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Seguridad física # Gestión de activos	# Protección

Control

Los activos fuera del sitio deben estar protegidos.

Objetivo

Para evitar la pérdida, el daño, el robo o el compromiso de los dispositivos externos y la interrupción de las operaciones de la organización.

Guía

Cualquier dispositivo utilizado fuera de las instalaciones de la organización que almacene o procese información (p. ej., dispositivo móvil), incluidos los dispositivos de propiedad de la organización y los dispositivos de propiedad privada y utilizados en nombre de la organización [traiga su propio dispositivo (BYOD)] necesita protección. El uso de estos dispositivos debe ser autorizado por la gerencia.

Se deben considerar las siguientes pautas para la protección de dispositivos que almacenan o procesan información fuera de las instalaciones de la organización:

- a) no dejar desatendidos equipos y medios de almacenamiento fuera de las instalaciones en lugares públicos y no seguros;
- b) observar las instrucciones de los fabricantes para proteger el equipo en todo momento (por ejemplo, protección contra la exposición a campos electromagnéticos fuertes, agua, calor, humedad, polvo);
- c) cuando se transfiere equipo fuera de las instalaciones entre diferentes personas o partes interesadas, mantener un registro que defina la cadena de custodia del equipo que incluya al menos los nombres y organizaciones de quienes son responsables del equipo. La información que no necesita transferirse con el activo debe eliminarse de forma segura antes de la transferencia;
- d) cuando sea necesario y práctico, exigir la autorización para retirar equipos y medios de las instalaciones de la organización y mantener un registro de tales retiros para mantener un registro de auditoría (ver [5.14](#));
- e) protección contra la visualización de información en un dispositivo (p. ej., móvil o portátil) en el transporte público, y los riesgos asociados con la navegación por el hombre;
- f) implementar el seguimiento de la ubicación y la capacidad para el borrado remoto de dispositivos.

La instalación permanente de equipos fuera de las instalaciones de la organización [como antenas y cajeros automáticos (ATM)] puede estar sujeta a un mayor riesgo de daño, robo o escuchas ilegales. Estos riesgos pueden variar considerablemente entre ubicaciones y deben tenerse en cuenta al determinar las medidas más apropiadas. Se deben considerar las siguientes pautas al colocar este equipo fuera de las instalaciones de la organización:

- a) vigilancia de la seguridad física (véase [7.4](#));
- b) protección contra amenazas físicas y ambientales (ver [7.5](#));
- c) controles de acceso físico ya prueba de manipulaciones;
- d) controles de acceso lógico.

Otra información

Puede encontrar más información sobre otros aspectos de la protección de equipos de almacenamiento y procesamiento de información y dispositivos de punto final de usuario en [8.1](#) y [6.7](#).

7.10 Medios de almacenamiento

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Seguridad física # Gestión de activos	# Protección

Control

Los medios de almacenamiento deben gestionarse a lo largo de su ciclo de vida de adquisición, uso, transporte y eliminación de acuerdo con el esquema de clasificación y los requisitos de manipulación de la organización.

Objetivo

Garantizar únicamente la divulgación, modificación, eliminación o destrucción autorizada de la información en los medios de almacenamiento.

Guía

Medios de almacenamiento extraíbles

Se deben considerar las siguientes pautas para la gestión de medios de almacenamiento extraíbles:

- a) establecer una política específica de un tema sobre la gestión de medios de almacenamiento extraíbles y comunicar dicha política específica de un tema a cualquier persona que use o manipule medios de almacenamiento extraíbles;
- b) cuando sea necesario y práctico, solicitar autorización para que los medios de almacenamiento se retiren de la organización y mantener un registro de tales retiros para mantener un registro de auditoría;
- c) almacenar todos los medios de almacenamiento en un entorno seguro y protegido de acuerdo con su clasificación de información y protegerlos contra amenazas ambientales (como calor, humedad, campo electrónico o envejecimiento), de acuerdo con las especificaciones de los fabricantes;
- d) si la confidencialidad o la integridad de la información son consideraciones importantes, usar técnicas criptográficas para proteger la información en medios de almacenamiento extraíbles;
- e) mitigar el riesgo de que los medios de almacenamiento se degraden mientras aún se necesita la información almacenada, transfiriendo la información a nuevos medios de almacenamiento antes de que se vuelva ilegible;
- f) almacenar múltiples copias de información valiosa en medios de almacenamiento separados para reducir aún más el riesgo de daño o pérdida de información coincidente;

- g) considerar el registro de medios de almacenamiento extraíbles para limitar la posibilidad de pérdida de información;
- h) solo habilitar puertos de medios de almacenamiento extraíbles [por ejemplo, ranuras para tarjetas Secure Digital (SD) y puertos de bus serie universal (USB)] si existe una razón organizativa para su uso;
- i) cuando sea necesario utilizar medios de almacenamiento extraíbles, monitorear la transferencia de información a dichos medios de almacenamiento;
- j) la información puede ser vulnerable al acceso no autorizado, mal uso o corrupción durante el transporte físico, por ejemplo, cuando se envían medios de almacenamiento a través del servicio postal o de mensajería.

En este control, los medios incluyen documentos en papel. Al transferir medios físicos de almacenamiento, aplique medidas de seguridad en [5.14](#).

Reutilización o eliminación segura

Deben establecerse procedimientos para la reutilización o eliminación segura de los medios de almacenamiento para minimizar el riesgo de fuga de información confidencial a personas no autorizadas. Los procedimientos para la reutilización o eliminación segura de medios de almacenamiento que contengan información confidencial deben ser proporcionales a la sensibilidad de esa información. Se deben considerar los siguientes elementos:

- a) si los medios de almacenamiento que contienen información confidencial deben reutilizarse dentro de la organización, eliminar datos de forma segura o formatear los medios de almacenamiento antes de su reutilización (ver [8.10](#));
- b) deshacerse de medios de almacenamiento que contengan información confidencial de forma segura cuando ya no se necesiten (p. ej., destruyendo, triturando o eliminando de forma segura el contenido);
- c) contar con procedimientos para identificar los artículos que pueden requerir una eliminación segura;
- d) muchas organizaciones ofrecen servicios de recogida y eliminación de medios de almacenamiento. Se debe tener cuidado al seleccionar un proveedor externo adecuado con controles y experiencia adecuados;
- e) registrar la eliminación de elementos sensibles para mantener un registro de auditoría;
- f) al acumular medios de almacenamiento para su eliminación, teniendo en cuenta el efecto de agregación, que puede hacer que una gran cantidad de información no confidencial se convierta en confidencial.

Se debe realizar una evaluación de riesgos en los dispositivos dañados que contienen datos confidenciales para determinar si los elementos deben destruirse físicamente en lugar de enviarse a reparar o desecharse (ver [7.14](#)).

Otra información

Cuando la información confidencial en los medios de almacenamiento no está encriptada, se debe considerar la protección física adicional de los medios de almacenamiento.

7.11 Utilidades de apoyo

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo # Detective	# Integridad # Disponibilidad	# Proteger #Detectar	# Seguridad física	# Protección

Control

Las instalaciones de procesamiento de información deben estar protegidas contra cortes de energía y otras interrupciones causadas por fallas en los servicios públicos de apoyo.

Objetivo

Para evitar la pérdida, el daño o el compromiso de la información y otros activos asociados, o la interrupción de las operaciones de la organización debido a fallas e interrupciones de los servicios públicos de apoyo.

Guía

Las organizaciones dependen de los servicios públicos (por ejemplo, electricidad, telecomunicaciones, suministro de agua, gas, alcantarillado, ventilación y aire acondicionado) para respaldar sus instalaciones de procesamiento de información. Por lo tanto, la organización debe:

- a) asegurarse de que el equipo de apoyo a los servicios públicos esté configurado, operado y mantenido de acuerdo con las especificaciones del fabricante correspondiente;
- b) asegurar que las empresas de servicios públicos sean evaluadas regularmente por su capacidad para cumplir con el crecimiento del negocio y las interacciones con otras empresas de servicios públicos de apoyo;
- c) asegurarse de que el equipo de apoyo a los servicios públicos sea inspeccionado y probado periódicamente para garantizar su correcto funcionamiento;
- d) si es necesario, activar alarmas para detectar fallas en los servicios públicos;
- e) si es necesario, asegurarse de que las empresas de servicios públicos tengan múltiples alimentaciones con diversas rutas físicas;
- f) asegurarse de que el equipo de apoyo a los servicios públicos esté en una red separada de las instalaciones de procesamiento de información si está conectado a una red;
- g) asegurarse de que el equipo que respalda a los servicios públicos esté conectado a Internet solo cuando sea necesario y solo de manera segura.

Se debe proporcionar iluminación de emergencia y comunicaciones. Los interruptores y válvulas de emergencia para cortar la energía, el agua, el gas u otros servicios públicos deben ubicarse cerca de las salidas de emergencia o las salas de equipos. Los detalles de los contactos de emergencia deben registrarse y estar disponibles para el personal en caso de un apagón.

Otra información

Se puede obtener redundancia adicional para la conectividad de la red mediante múltiples rutas de más de un proveedor de servicios públicos.

7.12 Seguridad del cableado

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Disponibilidad	# Proteger	# Seguridad física	# Protección

Control

Los cables que transportan energía, datos o servicios de información de apoyo deben protegerse contra interceptaciones, interferencias o daños.

Objetivo

Para evitar la pérdida, el daño, el robo o el compromiso de la información y otros activos asociados y la interrupción de las operaciones de la organización relacionadas con el cableado de energía y comunicaciones.

Guía

Se deben considerar las siguientes pautas para la seguridad del cableado:

- a) las líneas eléctricas y de telecomunicaciones a las instalaciones de procesamiento de información sean subterráneas cuando sea posible, o estén sujetas a una protección alternativa adecuada, como protectores de cables en el piso y postes de servicios públicos; si los cables son subterráneos, protegerlos de cortes accidentales (por ejemplo, con conductos blindados o señales de presencia);
- b) separar los cables de alimentación de los cables de comunicaciones para evitar interferencias;

c) para sistemas sensibles o críticos, los controles adicionales a considerar incluyen:

- 1) instalación de conductos blindados y cuartos o cajas cerradas y alarmas en los puntos de inspección y terminación;
- 2) uso de blindaje electromagnético para proteger los cables;
- 3) barridos técnicos periódicos e inspecciones físicas para detectar dispositivos no autorizados conectados a los cables;
- 4) acceso controlado a paneles de conexión y salas de cables (por ejemplo, con llaves mecánicas o PIN);
- 5) uso de cables de fibra óptica;

d) etiquetar los cables en cada extremo con suficientes detalles de origen y destino para permitir la identificación física y la inspección del cable.

Se debe buscar el asesoramiento de especialistas sobre cómo gestionar los riesgos derivados de incidentes o mal funcionamiento del cableado.

Otra información

A veces, el cableado de energía y telecomunicaciones son recursos compartidos por más de una organización que ocupa locales compartidos.

7.13 Mantenimiento de equipos

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Seguridad física # Gestión de activos	# Protección # Resiliencia

Control

El equipo debe mantenerse correctamente para garantizar la disponibilidad, integridad y confidencialidad de la información.

Objetivo

Para evitar la pérdida, daño, robo o compromiso de la información y otros activos asociados y la interrupción de las operaciones de la organización causada por la falta de mantenimiento.

Guía

Se deben considerar las siguientes pautas para el mantenimiento del equipo:

- a) mantener el equipo de acuerdo con la frecuencia y las especificaciones de servicio recomendadas por el proveedor;
- b) implementación y seguimiento de un programa de mantenimiento por parte de la organización;
- c) solo personal de mantenimiento autorizado que realice reparaciones y mantenimiento en el equipo;
- d) mantener registros de todas las fallas sospechadas o reales, y de todo mantenimiento preventivo y correctivo;
- e) implementar controles apropiados cuando el equipo esté programado para mantenimiento, teniendo en cuenta si este mantenimiento es realizado por personal en el sitio o externo a la organización; someter al personal de mantenimiento a un adecuado acuerdo de confidencialidad;
- f) supervisar al personal de mantenimiento al realizar el mantenimiento en el sitio;
- g) autorizar y controlar el acceso para el mantenimiento remoto;

- h) aplicar medidas de seguridad para activos fuera de las instalaciones (ver [7.9](#)) si el equipo que contiene información se retira de las instalaciones para su mantenimiento;
- i) cumplir con todos los requisitos de mantenimiento impuestos por el seguro;
- j) antes de volver a poner en funcionamiento el equipo después del mantenimiento, inspeccionarlo para asegurarse de que el equipo no haya sido manipulado y funcione correctamente;
- k) aplicar medidas para la eliminación segura o la reutilización de equipos (ver [7.14](#)) si se determina que el equipo debe desecharse.

Otra información

El equipo incluye componentes técnicos de las instalaciones de procesamiento de información, fuente de alimentación ininterrumpida (UPS) y baterías, generadores de energía, alternadores y convertidores de energía, sistemas y alarmas de detección de intrusos físicos, detectores de humo, extintores de incendios, aire acondicionado y ascensores.

7.14 Eliminación segura o reutilización de equipos

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad	# Proteger	# Seguridad física # Gestión de activos	# Protección

Control

Los elementos del equipo que contengan medios de almacenamiento deben verificarse para garantizar que todos los datos confidenciales y el software con licencia se hayan eliminado o sobrescrito de forma segura antes de su eliminación o reutilización.

Objetivo

Para evitar la fuga de información de los equipos que se desecharán o reutilizarán.

Guía

El equipo debe verificarse para garantizar si los medios de almacenamiento están contenidos o no antes de su eliminación o reutilización.

Los medios de almacenamiento que contengan información confidencial o con derechos de autor deben destruirse físicamente o la información debe destruirse, eliminarse o sobrescribirse utilizando técnicas para hacer que la información original no se pueda recuperar en lugar de utilizar la función de eliminación estándar. Ver [7.10](#) para obtener orientación detallada sobre la eliminación segura de medios de almacenamiento y [8.10](#) para obtener orientación sobre la eliminación de información.

Las etiquetas y marcas que identifiquen a la organización o que indiquen la clasificación, el propietario, el sistema o la red deben eliminarse antes de su eliminación, incluida la reventa o la donación a organizaciones benéficas.

La organización debe considerar la eliminación de los controles de seguridad, como los controles de acceso o el equipo de vigilancia, al final del contrato de arrendamiento o al mudarse de las instalaciones. Esto depende de factores como:

- a) su contrato de arrendamiento para devolver la instalación a su condición original;
- b) minimizar el riesgo de dejar los sistemas con información confidencial para el próximo inquilino (por ejemplo, listas de acceso de usuarios, archivos de video o imagen);
- c) la capacidad de reutilizar los controles en la siguiente instalación.

Otra información

Los equipos dañados que contienen medios de almacenamiento pueden requerir una evaluación de riesgos para determinar si los elementos deben destruirse físicamente en lugar de enviarse a reparar o desecharse. La información puede verse comprometida por la eliminación descuidada o la reutilización del equipo.

Además de la eliminación segura del disco, el cifrado de disco completo reduce el riesgo de divulgación de información confidencial cuando el equipo se desecha o se vuelve a implementar, siempre que:

- a) el proceso de encriptación es lo suficientemente fuerte y cubre todo el disco (incluido el espacio libre, los archivos de intercambio);
- b) las claves criptográficas son lo suficientemente largas para resistir ataques de fuerza bruta;
- c) las claves criptográficas se mantienen confidenciales (por ejemplo, nunca se almacenan en el mismo disco).

Para obtener más información sobre criptografía, consulte [8.24](#).

Las técnicas para sobrescribir de forma segura los medios de almacenamiento difieren según la tecnología de los medios de almacenamiento y el nivel de clasificación de la información en los medios de almacenamiento. Las herramientas de sobrescritura deben revisarse para asegurarse de que sean aplicables a la tecnología de los medios de almacenamiento.

Consulte ISO/IEC 27040 para obtener detalles sobre los métodos para desinfectar los medios de almacenamiento.

8 Controles tecnológicos

8.1 Dispositivos de punto final de usuario

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Seguridad de- red eléctrica
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	# Gestión de activos # Información_protección	# Protección

Control

La información almacenada, procesada o accesible a través de los dispositivos finales de los usuarios debe protegerse.

Objetivo

Para proteger la información contra los riesgos introducidos por el uso de dispositivos de punto final de usuario.

Guía

General

La organización debe establecer una política específica del tema sobre la configuración y el manejo seguros de los dispositivos de punto final del usuario. La política específica del tema debe comunicarse a todo el personal pertinente y considerar lo siguiente:

- a) el tipo de información y el nivel de clasificación que los dispositivos de punto final del usuario pueden manejar, procesar, almacenar o admitir;
- b) registro de dispositivos de punto final de usuario;
- c) requisitos de protección física;
- d) restricción de la instalación de software (p. ej., controlado de forma remota por los administradores del sistema);
- e) requisitos para el software del dispositivo de punto final del usuario (incluidas las versiones de software) y para aplicar actualizaciones (por ejemplo, actualización automática activa);
- f) reglas para la conexión a servicios de información, redes públicas o cualquier otra red fuera de las instalaciones (por ejemplo, que requiera el uso de un cortafuegos personal);
- g) controles de acceso;
- h) cifrado del dispositivo de almacenamiento;

i) protección contra malware;

j) deshabilitación, borrado o bloqueo remoto;

k) copias de seguridad;

l) uso de servicios web y aplicaciones web;

m) análisis del comportamiento del usuario final (ver [8.16](#));

n) el uso de dispositivos extraíbles, incluidos los dispositivos de memoria extraíbles, y la posibilidad de desactivar puertos físicos (por ejemplo, puertos USB);

o) el uso de capacidades de partición, si es compatible con el dispositivo de punto final del usuario, que puede separar de forma segura la información de la organización y otros activos asociados (por ejemplo, software) de otra información y otros activos asociados en el dispositivo.

Se debe considerar si cierta información es tan confidencial que solo se puede acceder a ella a través de los dispositivos de punto final del usuario, pero no se almacena en dichos dispositivos. En tales casos, se pueden requerir protecciones técnicas adicionales en el dispositivo. Por ejemplo, asegurarse de que la descarga de archivos para trabajar sin conexión esté deshabilitada y que el almacenamiento local, como la tarjeta SD, esté deshabilitado.

En la medida de lo posible, las recomendaciones sobre este control deben hacerse cumplir a través de la gestión de la configuración (ver [8.9](#)) o herramientas automatizadas.

responsabilidad del usuario

Todos los usuarios deben ser conscientes de los requisitos y procedimientos de seguridad para proteger los dispositivos de punto final de los usuarios, así como de sus responsabilidades para implementar dichas medidas de seguridad. Se debe recomendar a los usuarios que:

a) cerrar sesiones activas y cancelar servicios cuando ya no se necesiten;

b) proteger los dispositivos de punto final del usuario del uso no autorizado con un control físico (p. ej., bloqueo de teclas o bloqueos especiales) y un control lógico (p. ej., acceso con contraseña) cuando no estén en uso; no dejar desatendidos los dispositivos que transportan información comercial importante, confidencial o crítica;

c) usar dispositivos con especial cuidado en lugares públicos, oficinas abiertas, lugares de reunión y otras áreas no protegidas (por ejemplo, evitar leer información confidencial si las personas pueden leer por detrás, usar filtros de pantalla de privacidad);

d) proteger físicamente los dispositivos de punto final del usuario contra el robo (por ejemplo, en automóviles y otras formas de transporte, habitaciones de hotel, centros de conferencias y lugares de reunión).

Debe establecerse un procedimiento específico que tenga en cuenta los requisitos legales, estatutarios, reglamentarios, contractuales (incluidos los seguros) y otros requisitos de seguridad de la organización para casos de robo o pérdida de dispositivos de punto final de usuario.

Uso de dispositivos personales.

Cuando la organización permita el uso de dispositivos personales (a veces conocidos como BYOD), además de la orientación proporcionada en este control, se debe considerar lo siguiente:

a) separación del uso personal y comercial de los dispositivos, incluido el uso de software para respaldar dicha separación y proteger los datos comerciales en un dispositivo privado;

b) proporcionar acceso a la información comercial solo después de que los usuarios hayan reconocido sus deberes (protección física, actualización de software, etc.), renunciar a la propiedad de los datos comerciales, permitir que la organización borre datos de forma remota en caso de robo o pérdida del dispositivo o cuando ya no está autorizado a utilizar el servicio. En tales casos, se debe considerar la legislación de protección de PII;

c) políticas y procedimientos específicos del tema para prevenir disputas relacionadas con los derechos de propiedad intelectual desarrollados en equipos de propiedad privada;

d) acceso a equipos de propiedad privada (para verificar la seguridad de la máquina o durante una investigación), que puede ser impedido por la legislación;

e) acuerdos de licencia de software que son tales que las organizaciones pueden ser responsables de la concesión de licencias de software de cliente en dispositivos de punto final de usuario propiedad privada del personal o usuarios externos.

Conexiones inalámbricas

La organización debería establecer procedimientos para:

a) la configuración de conexiones inalámbricas en dispositivos (p. ej., desactivación de protocolos vulnerables);

b) usar conexiones inalámbricas o por cable con el ancho de banda adecuado de acuerdo con las políticas específicas del tema (por ejemplo, porque se necesitan copias de seguridad o actualizaciones de software).

Otra información

Los controles para proteger la información en los dispositivos de punto final del usuario dependen de si el dispositivo de punto final del usuario se usa solo dentro de las instalaciones seguras y las conexiones de red de la organización, o si está expuesto a mayores amenazas físicas y relacionadas con la red fuera de la organización.

Las conexiones inalámbricas para los dispositivos de punto final del usuario son similares a otros tipos de conexiones de red, pero tienen diferencias importantes que deben tenerse en cuenta al identificar los controles. En particular, la copia de seguridad de la información almacenada en los dispositivos de punto final del usuario a veces puede fallar debido al ancho de banda de red limitado o porque los dispositivos de punto final del usuario no están conectados en los momentos en que se programan las copias de seguridad.

Para algunos puertos USB, como USB-C, no es posible deshabilitar el puerto USB porque se usa para otros fines (por ejemplo, suministro de energía y salida de pantalla).

8.2 Derechos de acceso privilegiado

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Capacidad operativa Habilidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#identidad_y_ac- cess_management	# Proteccion

Control

La asignación y el uso de derechos de acceso privilegiado deben restringirse y gestionarse.

Objetivo

Para garantizar que solo los usuarios autorizados, los componentes y servicios de software reciban derechos de acceso privilegiado.

Guía

La asignación de derechos de acceso privilegiado debe controlarse a través de un proceso de autorización de acuerdo con la política de control de acceso específica del tema pertinente (ver [5.15](#)). Se debe considerar lo siguiente:

a) identificar a los usuarios que necesitan derechos de acceso privilegiado para cada sistema o proceso (por ejemplo, sistemas operativos, sistemas de gestión de bases de datos y aplicaciones);

b) asignar derechos de acceso privilegiado a los usuarios según sea necesario y caso por caso de acuerdo con la política específica del tema sobre control de acceso (ver [5.15](#)) (es decir, solo a personas con la competencia necesaria para llevar a cabo actividades que requieren un acceso privilegiado y con base en el requisito mínimo para sus roles funcionales);

- c) mantener un proceso de autorización (es decir, determinar quién puede aprobar derechos de acceso privilegiado o no otorgar derechos de acceso privilegiado hasta que se complete el proceso de autorización) y un registro de todos los privilegios asignados;
- d) definir e implementar los requisitos para la expiración de los derechos de acceso privilegiado;
- e) tomar medidas para garantizar que los usuarios conozcan sus derechos de acceso privilegiado y cuándo se encuentran en el modo de acceso privilegiado. Las posibles medidas incluyen el uso de identidades de usuario específicas, configuraciones de interfaz de usuario o incluso equipos específicos;
- f) los requisitos de autenticación para los derechos de acceso privilegiado pueden ser más altos que los requisitos para los derechos de acceso normales. Puede ser necesario volver a autenticarse o aumentar la autenticación antes de trabajar con derechos de acceso privilegiados;
- g) regularmente, y después de cualquier cambio organizacional, revisar a los usuarios que trabajan con derechos de acceso privilegiado para verificar si sus deberes, roles, responsabilidades y competencia aún los califican para trabajar con derechos de acceso privilegiado (ver [5.18](#));
- h) establecer reglas específicas para evitar el uso de identificaciones de usuario de administración genéricas (como "root"), dependiendo de las capacidades de configuración de los sistemas. Administrar y proteger la información de autenticación de dichas identidades (ver [5.17](#));
- i) otorgar acceso privilegiado temporal solo durante el período de tiempo necesario para implementar cambios o actividades aprobados (por ejemplo, para actividades de mantenimiento o algunos cambios críticos), en lugar de otorgar derechos de acceso privilegiado de forma permanente. Esto a menudo se conoce como procedimiento de rotura de cristal y, a menudo, se automatiza mediante tecnologías de gestión de acceso privilegiado;
- j) registrar todos los accesos privilegiados a los sistemas con fines de auditoría;
- k) no compartir o vincular identidades con derechos de acceso privilegiado a múltiples personas, asignando a cada persona una identidad separada que permita asignar derechos de acceso privilegiado específicos. Las identidades se pueden agrupar (p. ej., definiendo un grupo de administradores) para simplificar la gestión de los derechos de acceso privilegiado;
- l) usar únicamente identidades con derechos de acceso privilegiado para realizar tareas administrativas y no para tareas generales del día a día [es decir, revisar el correo electrónico, acceder a la web (los usuarios deben tener una identidad de red normal separada para estas actividades)].

Otra información

Los derechos de acceso privilegiado son derechos de acceso proporcionados a una identidad, un rol o un proceso que permite realizar actividades que los usuarios o procesos típicos no pueden realizar. Los roles de administrador del sistema generalmente requieren derechos de acceso privilegiado.

El uso inapropiado de los privilegios del administrador del sistema (cualquier característica o instalación de un sistema de información que permita al usuario anular los controles del sistema o de la aplicación) es un factor importante que contribuye a las fallas o violaciones de los sistemas.

Puede encontrar más información relacionada con la gestión de acceso y la gestión segura del acceso a la información y los recursos de tecnologías de la información y las comunicaciones en ISO/IEC 29146.

8.3 Restricción de acceso a la información

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#identidad_y_ac- cess_management	# Proteccion

Control

El acceso a la información y otros activos asociados debe estar restringido de acuerdo con la política específica del tema establecida sobre control de acceso.

Objetivo

Para garantizar solo el acceso autorizado y evitar el acceso no autorizado a la información y otros activos asociados.

Guía

El acceso a la información y otros activos asociados debe estar restringido de acuerdo con las políticas específicas del tema establecidas. Se debe considerar lo siguiente para respaldar los requisitos de restricción de acceso:

- a) no permitir el acceso a información sensible por parte de usuarios con identidades desconocidas o de forma anónima. El acceso público o anónimo solo debe otorgarse a ubicaciones de almacenamiento que no contengan información confidencial;
- b) proporcionar mecanismos de configuración para controlar el acceso a la información en sistemas, aplicaciones y servicios;
- c) controlar a qué datos puede acceder un usuario en particular;
- d) controlar qué identidades o grupo de identidades tienen qué acceso, como lectura, escritura, eliminación y ejecución;
- e) proporcionar controles de acceso físicos o lógicos para el aislamiento de aplicaciones sensibles, datos de aplicaciones o sistemas.

Además, se deben considerar técnicas y procesos de gestión de acceso dinámico para proteger información confidencial que tiene un gran valor para la organización cuando la organización:

- a) necesita un control granular sobre quién puede acceder a dicha información durante qué período y de qué manera;
- b) quiere compartir dicha información con personas ajenas a la organización y mantener el control sobre quién puede acceder a ella;
- c) quiere gestionar dinámicamente, en tiempo real, el uso y distribución de dicha información;
- d) quiere proteger dicha información contra cambios no autorizados, copia y distribución (incluida la impresión);
- e) quiere monitorear el uso de la información;
- f) quiere registrar cualquier cambio en dicha información que tenga lugar en caso de que se requiera una investigación futura.

Las técnicas de gestión de acceso dinámico deben proteger la información a lo largo de su ciclo de vida (es decir, creación, procesamiento, almacenamiento, transmisión y eliminación), incluyendo:

- a) establecer reglas sobre la gestión del acceso dinámico en función de casos de uso específicos considerando:
 - 1) otorgar permisos de acceso en función de la identidad, el dispositivo, la ubicación o la aplicación;
 - 2) aprovechar el esquema de clasificación para determinar qué información debe protegerse con técnicas de gestión de acceso dinámico;
- b) establecer procesos operativos, de seguimiento y de presentación de informes e infraestructura técnica de apoyo.

Los sistemas de gestión de acceso dinámico deben proteger la información mediante:

- a) exigir autenticación, credenciales apropiadas o un certificado para acceder a la información;
- b) restringir el acceso, por ejemplo, a un período de tiempo específico (por ejemplo, después de una fecha dada o hasta una fecha particular);
- c) usar cifrado para proteger la información;
- d) definir los permisos de impresión de la información;
- e) registrar quién accede a la información y cómo se utiliza la información;
- f) generar alertas si se detectan intentos de mal uso de la información.

Otra información

Las técnicas de gestión de acceso dinámico y otras tecnologías de protección de información dinámica pueden respaldar la protección de la información incluso cuando los datos se comparten más allá de la organización de origen, donde no se pueden aplicar los controles de acceso tradicionales. Se puede aplicar a documentos, correos electrónicos u otros archivos que contengan información para limitar quién puede acceder al contenido y de qué manera. Puede ser a nivel granular y adaptarse a lo largo del ciclo de vida de la información.

Las técnicas de gestión de acceso dinámico no reemplazan la gestión de acceso clásica [por ejemplo, el uso de listas de control de acceso (ACL)], pero pueden agregar más factores de condicionalidad, evaluación en tiempo real, reducción de datos justo a tiempo y otras mejoras que pueden ser útiles para la información más sensible. Ofrece una forma de controlar el acceso fuera del entorno de la organización. La respuesta a incidentes se puede respaldar con técnicas de gestión de acceso dinámico, ya que los permisos se pueden modificar o revocar en cualquier momento.

En ISO/IEC 29146 se proporciona información adicional sobre un marco para la gestión de acceso.

8.4 Acceso al código fuente

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#Identidad_y_acceso_gestión #Aplicación_seguridad # Secure_configuración	# Protección

Control

El acceso de lectura y escritura al código fuente, las herramientas de desarrollo y las bibliotecas de software debe administrarse adecuadamente.

Objetivo

Para evitar la introducción de funciones no autorizadas, evitar cambios no intencionales o maliciosos y mantener la confidencialidad de la propiedad intelectual valiosa.

Guía

El acceso al código fuente y elementos asociados (como diseños, especificaciones, planes de verificación y planes de validación) y herramientas de desarrollo (por ejemplo, compiladores, constructores, herramientas de integración, plataformas y entornos de prueba) debe controlarse estrictamente.

Para el código fuente, esto se puede lograr controlando el almacenamiento central de dicho código, preferiblemente en el sistema de gestión de código fuente.

El acceso de lectura y el acceso de escritura al código fuente pueden diferir según la función del personal. Por ejemplo, el acceso de lectura al código fuente puede proporcionarse ampliamente dentro de la organización, pero el acceso de escritura al código fuente

solo está disponible para personal privilegiado o propietarios designados. Cuando los componentes del código son utilizados por varios desarrolladores dentro de una organización, se debe implementar el acceso de lectura a un repositorio de código centralizado. Además, si dentro de una organización se utiliza código fuente abierto o componentes de código de terceros, el acceso de lectura a dichos repositorios de código externos puede proporcionarse ampliamente. Sin embargo, el acceso de escritura aún debe estar restringido.

Se deben considerar las siguientes pautas para controlar el acceso a las bibliotecas de fuentes de programas a fin de reducir el potencial de corrupción de los programas de computadora:

- a) administrar el acceso al código fuente del programa y las bibliotecas fuente del programa de acuerdo con los procedimientos establecidos;
- b) otorgar acceso de lectura y escritura al código fuente en función de las necesidades comerciales y administrado para abordar los riesgos de alteración o uso indebido y de acuerdo con los procedimientos establecidos;
- c) actualización del código fuente y elementos asociados y otorgamiento de acceso al código fuente de acuerdo con los procedimientos de control de cambios (ver [8.32](#)) y solo realizarlo después de haber recibido la autorización correspondiente;
- d) no otorgar a los desarrolladores acceso directo al repositorio del código fuente, sino a través de herramientas para desarrolladores que controlan las actividades y autorizaciones en el código fuente;
- e) mantener las listas de programas en un entorno seguro, donde el acceso de lectura y escritura debe administrarse y asignarse adecuadamente;
- f) mantener un registro de auditoría de todos los accesos y de todos los cambios en el código fuente.

Si se pretende publicar el código fuente del programa, se deben considerar controles adicionales para garantizar su integridad (p. ej., firma digital).

Otra información

Si el acceso al código fuente no se controla adecuadamente, el código fuente puede modificarse o algunos datos en el entorno de desarrollo (por ejemplo, copias de datos de producción, detalles de configuración) pueden ser recuperados por personas no autorizadas.

8.5 Autenticación segura

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger	#identidad_y_ac- cess_management	# Proteccion

Control

Las tecnologías y los procedimientos de autenticación segura deben implementarse en función de las restricciones de acceso a la información y la política específica del tema sobre el control de acceso.

Objetivo

Para garantizar que un usuario o una entidad se autentica de forma segura cuando se otorga acceso a sistemas, aplicaciones y servicios.

Guía

Se debe elegir una técnica de autenticación adecuada para corroborar la identidad reclamada de un usuario, software, mensajes y otras entidades.

La fuerza de la autenticación debe ser adecuada para la clasificación de la información a la que se accede. Cuando se requiera una fuerte autenticación y verificación de identidad, los métodos de autenticación

Se deben utilizar alternativas a las contraseñas, como certificados digitales, tarjetas inteligentes, tokens o medios biométricos.

La información de autenticación debe ir acompañada de factores de autenticación adicionales para acceder a los sistemas de información crítica (también conocida como autenticación de múltiples factores). El uso de una combinación de múltiples factores de autenticación, como lo que sabe, lo que tiene y lo que es, reduce las posibilidades de accesos no autorizados. La autenticación multifactor se puede combinar con otras técnicas para requerir factores adicionales en circunstancias específicas, en función de reglas y patrones predefinidos, como el acceso desde una ubicación inusual, desde un dispositivo inusual o en un momento inusual.

La información de autenticación biométrica debe invalidarse si alguna vez se ve comprometida. La autenticación biométrica puede no estar disponible según las condiciones de uso (p. ej., humedad o envejecimiento). Para prepararse para estos problemas, la autenticación biométrica debe ir acompañada de al menos una técnica de autenticación alternativa.

El procedimiento para iniciar sesión en un sistema o aplicación debe estar diseñado para minimizar el riesgo de acceso no autorizado. Los procedimientos y tecnologías de inicio de sesión deben implementarse teniendo en cuenta lo siguiente:

- a) no mostrar información confidencial del sistema o de la aplicación hasta que el proceso de inicio de sesión se haya completado con éxito para evitar proporcionar asistencia innecesaria a un usuario no autorizado;
- b) exhibir un aviso general advirtiendo que el sistema o la aplicación o el servicio solo deben ser accedidos por usuarios autorizados;
- c) no proporcionar mensajes de ayuda durante el procedimiento de inicio de sesión que ayuden a un usuario no autorizado (por ejemplo, si surge una condición de error, el sistema no debe indicar qué parte de los datos es correcta o incorrecta);
- d) validar la información de inicio de sesión solo al completar todos los datos de entrada;
- e) protección contra intentos de inicio de sesión de fuerza bruta en nombres de usuario y contraseñas [p. ej., usar una prueba de Turing pública completamente automatizada para diferenciar computadoras y humanos (CAPTCHA), requerir el restablecimiento de la contraseña después de un número predefinido de intentos fallidos o bloquear al usuario después de un número máximo de errores];
- f) registrar intentos fallidos y exitosos;
- g) generar un evento de seguridad si se detecta un intento potencial o una violación exitosa de los controles de inicio de sesión (p. ej., enviar una alerta al usuario ya los administradores del sistema de la organización cuando se alcanza un cierto número de intentos de contraseña incorrectos);
- h) mostrar o enviar la siguiente información en un canal separado al completar un inicio de sesión exitoso:
 - 1) fecha y hora del inicio de sesión exitoso anterior;
 - 2) detalles de cualquier intento fallido de inicio de sesión desde el último inicio de sesión exitoso;
- i) no mostrar una contraseña en texto claro cuando se ingresa; en algunos casos, puede ser necesario desactivar esta funcionalidad para facilitar el inicio de sesión del usuario (por ejemplo, por razones de accesibilidad o para evitar el bloqueo de usuarios debido a errores repetidos);
- j) no transmitir contraseñas en texto claro a través de una red para evitar ser capturado por un programa "sniffer" de la red;
- k) finalizar sesiones inactivas después de un período definido de inactividad, especialmente en ubicaciones de alto riesgo, como áreas públicas o externas fuera de la gestión de seguridad de la organización o en los dispositivos de punto final del usuario;

l) restringir los tiempos de duración de la conexión para proporcionar seguridad adicional para aplicaciones de alto riesgo y reducir la ventana de oportunidad para el acceso no autorizado.

Otra información

Se puede encontrar información adicional sobre la garantía de autenticación de entidades en ISO/IEC 29115.

8.6 Gestión de la capacidad

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo # Detectivo	# Integridad # Disponibilidad	# Identificar # Proteger # Detectar	# Continuidad	# Gobernanza_y_ Ecosistema #Protec- ción

Control

El uso de los recursos debe monitorearse y ajustarse de acuerdo con los requisitos de capacidad actuales y esperados.

Objetivo

Asegurar la capacidad requerida de las instalaciones de procesamiento de información, recursos humanos, oficinas y otras instalaciones.

Guía

Deben identificarse los requisitos de capacidad para las instalaciones de procesamiento de información, los recursos humanos, las oficinas y otras instalaciones, teniendo en cuenta la importancia comercial de los sistemas y procesos en cuestión.

Se debe aplicar el ajuste y la supervisión del sistema para garantizar y, cuando sea necesario, mejorar la disponibilidad y la eficiencia de los sistemas.

La organización debería realizar pruebas de estrés de los sistemas y servicios para confirmar que hay suficiente capacidad del sistema disponible para cumplir con los requisitos de rendimiento máximo.

Deben establecerse controles de detección para indicar los problemas a su debido tiempo.

Las proyecciones de los futuros requisitos de capacidad deben tener en cuenta los nuevos requisitos del negocio y del sistema y las tendencias actuales y proyectadas en las capacidades de procesamiento de información de la organización.

Se debe prestar especial atención a cualquier recurso con largos plazos de entrega o altos costos. Por lo tanto, los gerentes, propietarios de servicios o productos deben monitorear la utilización de los recursos clave del sistema.

Los gerentes deben usar la información de capacidad para identificar y evitar posibles limitaciones de recursos y dependencia del personal clave que pueden representar una amenaza para la seguridad del sistema o los servicios y planificar la acción adecuada.

Se puede lograr proporcionar capacidad suficiente aumentando la capacidad o reduciendo la demanda. Se debe considerar lo siguiente para aumentar la capacidad:

- a) contratación de nuevo personal;
- b) obtención de nuevas instalaciones o espacio;
- c) adquirir sistemas de procesamiento, memoria y almacenamiento más potentes;
- d) hacer uso de la computación en la nube, que tiene características inherentes que abordan directamente cuestiones de capacidad. La computación en la nube tiene elasticidad y escalabilidad que permiten una rápida expansión y reducción bajo demanda de los recursos disponibles para aplicaciones y servicios particulares.

Se debe considerar lo siguiente para reducir la demanda de los recursos de la organización:

- a) eliminación de datos obsoletos (espacio en disco);
- b) eliminación de registros impresos que hayan cumplido su período de retención (liberar espacio en los estantes);
- c) desmantelamiento de aplicaciones, sistemas, bases de datos o entornos;
- d) optimizar procesos por lotes y cronogramas;
- e) optimizar el código de la aplicación o las consultas de la base de datos;
- f) denegar o restringir el ancho de banda para los servicios que consumen recursos si estos no son críticos (por ejemplo, transmisión de video).

Se debe considerar un plan de gestión de capacidad documentado para los sistemas de misión crítica.

Otra información

Para obtener más detalles sobre la elasticidad y escalabilidad de la computación en la nube, consulte ISO/IEC TS 23167.

8.7 Protección contra malware

Tipo de control	Información propiedades de seguridad	La seguridad cibernética conceptos	Operacional capacidades	Dominios de seguridad
# Preventivo # Detective # Correctivo	# Confidencialidad # Integridad # Disponibilidad	# Proteger #Detectar	# Sistema_y_red_ seguridad # Information_protec- ción	# Proteccion # Defensa

Control

La protección contra el malware debe implementarse y respaldarse mediante la conciencia adecuada del usuario.

Objetivo

Para garantizar que la información y otros activos asociados estén protegidos contra malware.

Guía

La protección contra el malware debe basarse en el software de detección y reparación de malware, la conciencia de seguridad de la información, el acceso adecuado al sistema y los controles de gestión de cambios. El uso de software de detección y reparación de malware por sí solo no suele ser adecuado. Se debe considerar la siguiente orientación:

- a) implementar reglas y controles que prevengan o detecten el uso de software no autorizado [por ejemplo, lista de aplicaciones permitidas (es decir, usar una lista que proporcione aplicaciones permitidas)] (ver [8.19](#) y [8.32](#));
- b) implementar controles que eviten o detecten el uso de sitios web maliciosos conocidos o sospechosos (por ejemplo, listas de bloqueo);
- c) reducir las vulnerabilidades que pueden ser explotadas por malware [por ejemplo, a través de la gestión técnica de vulnerabilidades (ver [8.8](#) y [8.19](#))];
- d) llevar a cabo una validación automatizada periódica del software y el contenido de datos de los sistemas, especialmente para los sistemas que soportan procesos comerciales críticos; investigar la presencia de archivos no aprobados o enmiendas no autorizadas;
- e) establecer medidas de protección contra los riesgos asociados con la obtención de archivos y software ya sea desde oa través de redes externas o en cualquier otro medio;